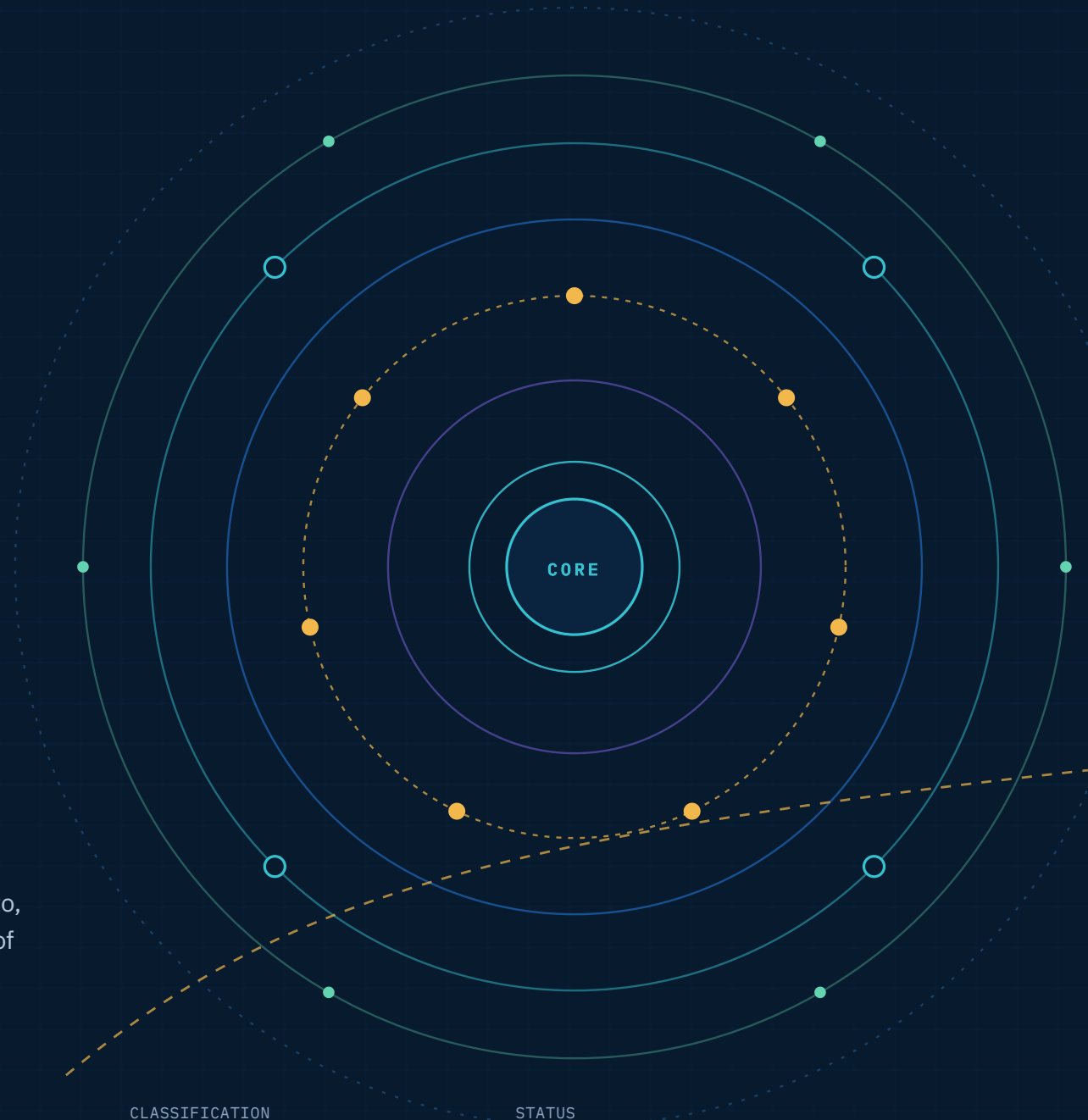


One platform for aerospace intelligence, maintenance & compliance

The verified current architecture, the target it should grow into, and the decisions in between — built from a code-level audit of the Aerocomply repository.



VOLUME 1

Contents

Thirty-six sections, fourteen mandatory diagram families plus supporting views. Every diagram carries a status label; every claim of implementation is backed by code evidence or marked otherwise.

FOUNDATIONS

01	Reading guide & status legend	03
02	Executive architecture overview	04
03	Audit inventory & evidence	05
04	Product vision & architectural principles	06

THE SYSTEM

05	Master ecosystem map — D01	07
06	Suite architecture	09
07	Layered architecture — D02	10
08	Backend modular monolith — D03	11
09	Module catalogue	12
10	Domain ownership & dependency boundaries	15
11	Infrastructure topology — D04	16
12	Current vs target infrastructure	17
13	Data architecture & contracts	18

DATA & INTELLIGENCE

14	Telemetry & connectivity — D05	19
15	Connectivity options & dependencies	20
16	HUMS processing — D06	21
17	M7, M14-ext and M4.2 ownership — D07	22
18	LISA & agentic AI — D08	23
19	Agentic workflows	24

OPERATIONS & GOVERNANCE

20	Compliance & rules engine — D09	25
21	MRO & asset lifecycle — D10	26
22	Plans & entitlements — D11	27
23	Security & trust boundaries — D12	28
24	Security controls & sovereignty	29
25	Deployment topology — D13	30
26	Reliability & observability	31
27	Integration & event architecture	32

SCENARIOS, STATUS & DECISIONS

28	Scenario 1 — drone anomaly to maintenance	33
29	Scenario 2 — compliance obligation	34
30	Scenario 3 — subscription to access	35
31	Implementation status register	36
32	Architecture gaps & corrections	37
33	Recommended technical roadmap	38
34	Architecture decision register	40
35	Decisions & trade-offs requiring approval	41
36	Glossary, legend & change history	42

Document control

Edition	v1.0 — first publication
Date	1 October 2026
Evidence	Aerocomply repository, branch feature/post-freeze-productionization , commit 6bd38ce
Method	Source, migrations, routes, tests, CI, docs read; backend and frontend suites re-run independently
Not inspected	Hosted environments, production data, hardware, provider consoles
Sources	Editable SVG / Python / Markdown in docs/architecture-blueprint/
Owner	[Architecture owner — to be assigned]

Three rules this document follows

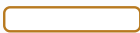
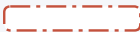
- Reports are not proof: historical claims were re-checked against code.
- Every diagram says whether it shows what exists, what is planned, or both.
- External validation (hardware, providers, UAT, pen test) is never implied.

HOW TO READ THIS BLUEPRINT

01 Reading guide & status legend

One visual language is used on every page. Status is encoded three ways — icon, label and border style — so it survives greyscale printing. Colour carries meaning, never decoration.

Implementation status

LABEL	MEANING	BORDER
 VERIFIED	code, migration and passing tests found in the repository	
 PARTIAL	works with documented limits or missing pieces	
 DESIGNED	an ADR or spec exists; no code	
 PROPOSED	recommended by this blueprint; not yet decided	
 EXTERNAL	needs hardware, credentials, provider or field validation	
 VERIFY	claimed in documents, not confirmed in code during this audit	
 SUPERSEDED	replaced by a later decision; kept for history	

A component is **VERIFIED** only when code, a migration (where data is involved) and a passing test were found. Documents alone never earn VERIFIED.

Connectors

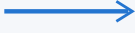
LINE	MEANING
	Synchronous request / call
	Asynchronous job / event
	Data persistence (write / read)
	Observability (logs, metrics, health)
	Human review / approval step
	Feedback / outcome loop
	Prohibited dependency
	Proposed path (not built)

Diagram scope labels

 CURRENT VERIFIED	what the code does today
 TARGET / PROPOSED	recommended, not built
 HYBRID	both, distinguished by status per element

Semantic colour

COLOUR	USED FOR
	Blue Infrastructure, runtime, connectivity
	Cyan Data movement, ingestion, storage
	Teal Operational and domain processing
	Amber Evaluation, findings, signals, decisions
	Purple AI, LISA and orchestration
	Coral Warnings, exceptions, risk boundaries
	Mint Governance, audit, commercial control
	Slate External systems and providers

Numbered callouts

Amber, cyan and mint discs on diagrams map to explanation lists and page references. Mono text in boxes is the repository path or table that proves the element.

THE SHORT VERSION

02 Executive architecture overview

Kota Aerospace is a working, well-tested modular monolith on a single PostgreSQL store. The software foundation is stronger than most platforms at this stage; the open work is at the edges — field connectivity, cross-path authorisation, decision lineage and production operations — not in the core.

HYBRID

2 689

backend tests passed in this audit's independent run (1 failed — test race)

383

frontend unit tests passed (vitest, 37 files)

70

Alembic migrations — clean upgrade 0001 → 0070 on empty PostgreSQL 16

61

LISA tools, each gated by permission + suite + feature

4

suites on one core: Aircraft, Drone/UAV, Helicopter, eVTOL/AAM

0

hardware, provider or customer validations performed — all EXTERNAL

What is verifiably true today

- **One deployable** FastAPI backend (57 routers, 523 handlers) + Next.js 16 frontend, three runtime processes: API, worker/scheduler, listeners.
- **PostgreSQL is the only store of truth** — including telemetry, the job queue and an immutable audit log. No broker, no Neo4j, no TimescaleDB in use.
- **Acquisition:** MAVLink v1/v2 (CRC, sequence, signing), MQTT, signed webhooks, OEM polling, CSV/JSON — all converge on one idempotent pipeline with quarantine.
- **HUMS → M7 → LISA** chain is deterministic and grounded; RUL is labelled an estimate.
- **Suite → plan → subscription** entitlements resolve per request in one resolver used by REST and LISA.
- **Compliance:** three-valued applicability with configuration snapshots and reasoning traces.

What needs a decision or correction → [p.37](#)

- **F1** ADR-003 still says Neo4j; the code chose PostgreSQL. Supersede it (ADR-011).
- **F3** Workers, listeners and pollers do not re-check entitlements — a cancelled tenant keeps ingesting.
- **F4** Edge store-and-forward is in memory and MAVLink is stamped with arrival time.
- **F7** Signal vocabulary drift, including a live defect: overdue work orders in PLANNED / ASSIGNED / ON_HOLD / INSPECTION never raise M7 signals.
- **F5 • F8** AI write boundary and compliance decision lineage are weaker than ADR-004/005 promise.
- **Not started:** physical bench, pen test, restore drill, provider validation, customer UAT.

Recommendation: finish the foundations (acquisition, authorisation, lineage, operations) before adding agentic or predictive features.

RUNTIME

API · worker + scheduler · listeners — one image, three processes. [p.16](#)

DATA

PostgreSQL 16 for everything of record; S3-compatible files; derived views in SQL. [p.18](#)

INTELLIGENCE

Deterministic HUMS → M7 signals → grounded LISA; no learned models yet. [p.22](#)

GOVERNANCE

Per-request RBAC + entitlements, immutable audit, retention by policy. [p.27](#)

PHASE 1 — WHAT WAS INSPECTED AND WHAT IT PROVED

03 Audit inventory & evidence

Historical reports were treated as claims. Each claim was checked against code, migrations and a fresh test run; this page records the verdict.

CURRENT

VERIFIED

Historical claims → verdict

CLAIM (FROM EARLIER REPORTS)	EVIDENCE FOUND IN THIS AUDIT	VERDICT
HUMS and telemetry foundations	Code, migrations 0051–0058, 0070; tests	✓ VERIFIED
M13 Phase 3 telemetry integration	telemetry_service, acquisition pipeline, tests	✓ VERIFIED
M7 proactive intelligence	proactive_intelligence_service; lifecycle audited; one vocabulary defect	⦿ PARTIAL
M14 cross-asset intelligence	Descriptive distributions only (H8.1 foundation)	⦿ PARTIAL
Grounded LISA tools	61 tools, 257-case matrix; tool calls not persisted to audit	⦿ PARTIAL
Suite and subscription architecture	Migrations 0059, 0061, 0064, 0069; resolver; tests	✓ VERIFIED
Staging deployments	Reports only (Vercel, Render, Neon); not inspected	⚙️ VERIFY
Historical test baseline (2 690 passed)	Re-run: 2 689 passed, 1 failed (start-up race), Python 3.12	⦿ PARTIAL
Neo4j derived graph (ADR-003, M14 report)	Not used in code; PostgreSQL-only derived views	✕ SUPERSEDED
Redis / TimescaleDB / Cloudflare topology	Target text in deployment guide; not built	◊ DESIGNED
ai_tool_audit_log (LISA doc)	No such table or writer in code	⚙️ VERIFY
RPO < 15 min, RTO < 1 h, WORM evidence	Runbook targets; no drill or bucket policy in repo	⚙️ VERIFY

Sources inspected

AREA	SCOPE
Backend	346 Python files · 57 routers · 95 models · services, listeners, worker, scheduler
Database	70 Alembic migrations, upgraded on an empty PostgreSQL 16
Tests	214 backend test files re-run (pytest, Python 3.12); vitest re-run
Frontend	Next.js 16.3.5 · 137 pages · entitlement guard · mock-route redirects
Runtime & CI	Dockerfile, docker-compose, GitHub Actions ci.yml, vercel link
Documents	10 ADRs, ontology, ~120 milestone reports and architecture notes
Not reachable	Staging / production hosts, provider consoles, physical devices

Independent test run

2689 passed · **1** failed · 16 deselected (real-storage) · 651 s on Python 3.12.3 + PostgreSQL 16.

Failed: test_supervisor_starts_a_tcp_listener — the test connects before the listener has bound its port (no readiness wait). Under Python 3.11 (the CI pin) one test file fails to collect.

Frontend: vitest 37 files / 383 tests passed · tsc clean · ESLint 0 errors, 129 warnings.

WHY THE PLATFORM IS SHAPED THIS WAY

04 Product vision & architectural principles

Kota connects physical aerospace assets, telemetry, health intelligence, maintenance and compliance through one grounded decision layer. The twelve principles below are the brief's own; each is scored against the code.

PRINCIPLE	IN CODE	EVIDENCE AND GAP
Modular monolith by default	✓ VERIFIED	One FastAPI deployable; boundaries by convention — import-linter not configured (F5).
PostgreSQL authoritative	✓ VERIFIED	All transactional, telemetry, audit and job data.
Neo4j as derived index	✗ SUPERSEDED	Code uses PostgreSQL derived views; brief and ADR-003 need reconciling (F1).
Domain ownership of logic, signals, evidence	🕒 PARTIAL	Clear in services; M7 vocabulary drift and two proactive surfaces (F7).
Event-driven where valuable	🕒 PARTIAL	Durable job queue + audit log as event log; no versioned event contract (F2).
Transactional outbox	🕒 PARTIAL	Jobs enqueued inside the request transaction = outbox-equivalent; not a formal outbox.
Grounded, permission-aware LISA	✓ VERIFIED	Per-call authorisation; UNKNOWN when data absent; safety guard.
Suite-specific plans & subscriptions	✓ VERIFIED	Plan belongs to one suite; one subscription per suite.
Tenant isolation & authZ in the backend	🕒 PARTIAL	Strong on HTTP; async ingestion paths skip entitlement (F3).
Automated telemetry acquisition	🕒 PARTIAL	Software complete; field paths external; durable edge buffer missing (F4).
Traceability observation → action	🕒 PARTIAL	IDs link packet to finding; signal ↔ work order via metadata only.
Human approval for regulated actions	🕒 PARTIAL	Release gates and RII are human; ADR-005 lineage not built (F8).

Product scope

Drones and unmanned aircraft · conventional aircraft · helicopters · eVTOL · operators and fleets · MRO organisations · compliance and engineering teams.

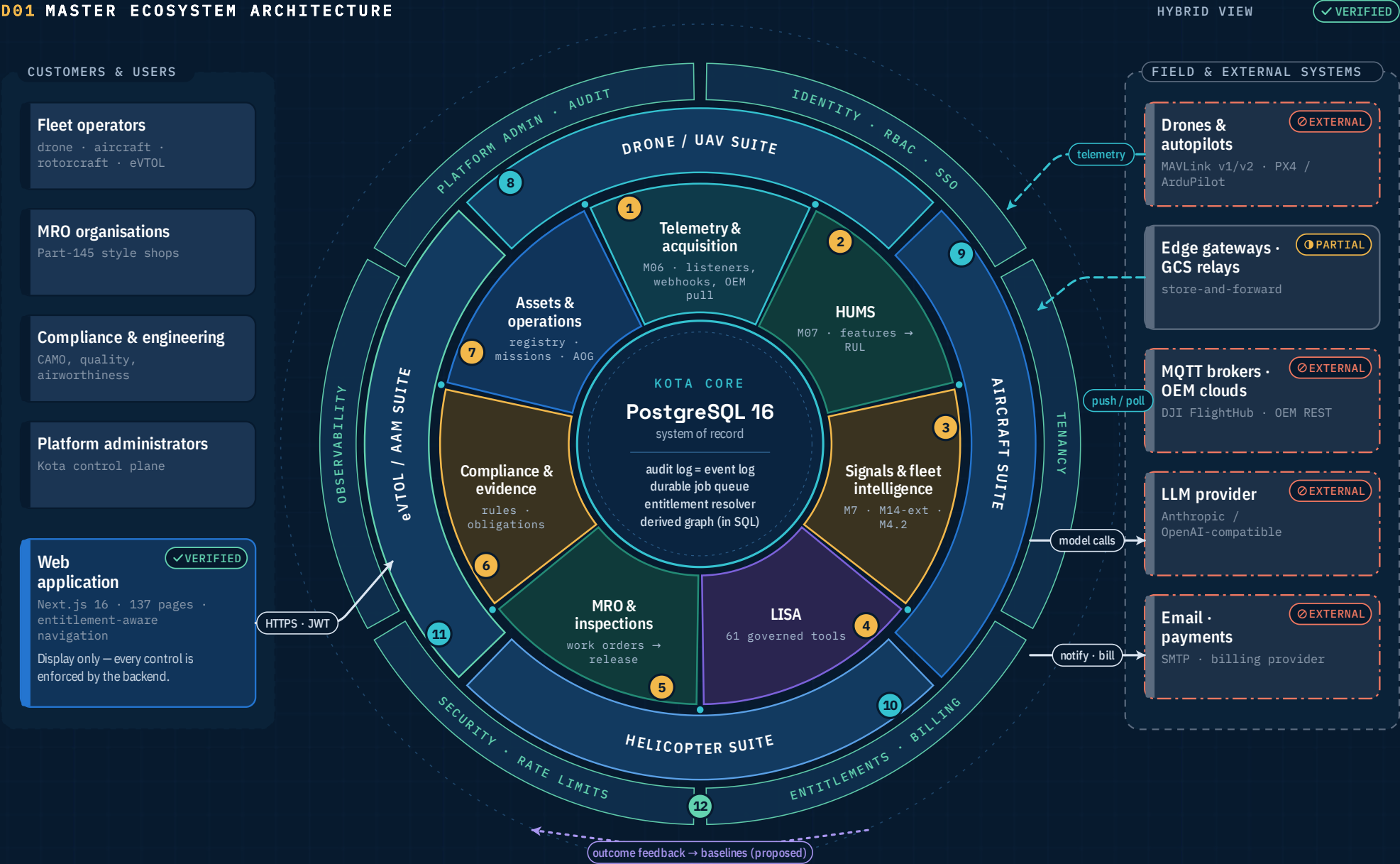
Complexity budget

No microservices, broker, graph database or additional agents unless a concrete requirement appears. The repository already proves the point: a PostgreSQL queue with SKIP LOCKED replaced a planned Redis broker, and SQL views replaced Neo4j.

Non-negotiables

- No AI-made compliance or airworthiness determinations.
- No data attached to an asset by guessing.
- No estimate presented as a certified life limit.
- No access decided by the frontend.

D01 MASTER ECOSYSTEM ARCHITECTURE



05 Master ecosystem map — guide

The map is drawn as rings because every capability shares one core. Clockwise in the domain ring is the direction data normally travels: from telemetry through health intelligence and signals to people, work and compliance, and back into the asset record.

HYBRID

- 1

Telemetry & acquisition — listeners, webhooks, OEM pull, batch import; one idempotent pipeline. [p.19](#)
- 2

HUMS — features, baselines, signatures, exceedances, RUL estimates. [p.21](#)
- 3

Signals & fleet intelligence — M7 owns actionable signals; M14-ext describes; M4.2 presents. [p.22](#)
- 4

LISA — 61 tools, each authorised per call; refuses airworthiness determinations. [p.23](#)
- 5

MRO & inspections — work orders, tasks, RII, parts, release-readiness gate. [p.26](#)
- 6

Compliance & evidence — requirements, Kleene applicability, obligations, evidence review. [p.25](#)
- 7

Assets & operations — registry for four families, configuration, missions, AOG. [p.18](#)
- 8

Drone / UAV suite — missions, batteries, MAVLink, HUMS starter sensors. [p.09](#)
- 9

Aircraft suite — maintenance programme, AOG, compliance, release readiness. [p.09](#)
- 10

Helicopter suite — rotor-system details, components; rotor analytics need OEM data. [p.09](#)
- 11

eVTOL / AAM suite — propulsion / HV details, batteries; OEM models external. [p.09](#)
- 12

Platform ring — identity, tenancy, entitlements, security, observability, admin. [p.28](#)

Dependencies that matter

- Every ring depends on the core store; nothing depends on the suites.
- Suites are configuration (catalogue, plans, detail tables), not separate code bases.
- LISA reads every domain but writes none (one exception, see D08).

What the map does not claim

- Field devices, brokers, OEM clouds and model providers are drawn outside the boundary and are EXTERNAL.
- The outcome-feedback loop is proposed.
- Hosting is reported, not inspected (D04, D13).

Interpretation

Read inside-out for ownership, clockwise for data, and outward for who is affected. Each numbered disc opens a detailed page.

FOUR SUITES, ONE PLATFORM

06 Suite architecture

A suite is a commercial and navigational boundary over shared modules — not a separate application. Suites, modules, pages and features are catalogue rows; a plan belongs to exactly one suite.

CURRENT VERIFIED

SUITE	CAPABILITIES	FAMILY-SPECIFIC DATA	STATUS	EXTERNAL DEPENDENCY
Aircraft AIRCRAFT	Fleet, flights, maintenance programme, work orders, inspections, compliance, AOG, release readiness	Aircraft detail tables; engines & components register	✓ VERIFIED	—
Drone / UAV DRONE_UAV	Fleet, missions, flights, batteries, telemetry, HUMS, M7, LISA	MAVLink, MQTT, DJI webhook, OEM polling	✓ VERIFIED	Physical links EXTERNAL
Helicopter HELICOPTER	Rotor-system details, components (rotor / transmission / engine), hours & cycles, HUMS starter sensors, per-sensor limits	airframe_details (0068), hums_templates	✓ VERIFIED	Track & balance, gearbox CI — OEM data
eVTOL / AAM EVTOL_AAM	Propulsion / HV details, batteries, components, hours & cycles, HUMS starter sensors	same tables; voltage/current/temperature/vibration	✓ VERIFIED	Propulsor efficiency, thermal models — OEM data

Shared by every suite

Asset registry, telemetry pipeline, HUMS engines, M7, LISA, MRO, compliance, evidence, audit, identity and tenancy. The generic /assets endpoint checks the family's feature so it is not a side door (_FAMILY_FEATURE).

Suite boundary rules

Plan features outside the suite's domain are refused; tenant overrides cannot cross suites; subscriptions cannot move to another suite's plan. **Gap:** the domain rules live in code (_SUITE_DISALLOWED_FEATURES), so a new suite with a new domain needs a release.

Multi-suite organisations

One current subscription per suite; an organisation can hold several suites. LISA matches tools against the suites actually held (a defect locking multi-suite tenants out was fixed). See D11 [p.27](#).

Adding a fifth suite — what is data and what is code

1 · DATA

Catalogue rows: suite, modules, pages, features (platform API). Frontend navigation follows automatically.

2 · DATA

Suite-specific plans with features and limits; subscriptions per organisation.

3 · CODE

Domain boundary rule in is_feature_allowed_for_suite; router feature gates for any new family endpoints.

4 · CODE + MIGRATION

Family detail table, HUMS starter template, UI pages, journey test — as done for helicopter / eVTOL in 0068.

D02 · ALLOWED AND PROHIBITED DEPENDENCIES

07 Layered architecture

Seven stacked layers plus a cross-cutting governance column. Calls flow down only; governance applies to every layer.

HYBRID



HOW TO READ

Each chip's icon is its status. The red strip lists dependencies that must never appear in code review; the first two are enforced by design today (no DB credentials in the browser; LISA uses service functions), the last two by convention. → [module map p.11](#) · [boundaries p.15](#)

D03 · EIGHTEEN MODULES IN ONE DEPLOYABLE

08 Backend modular monolith

Modules are service packages inside one FastAPI application sharing one PostgreSQL schema.
Arrows show the main runtime flows; full dependencies are in the matrix.

CURRENT VERIFIED



HOW TO READ

Module ids (M01–M17, X01) are this blueprint's; mono text is the main source file. Note: ADR-001 names folders `ai/`, `graph/`, `rules_engine/`, `document_intel/` — these exist but are empty; the code lives under `services/`. → [catalogue p.12](#) · [ownership p.15](#)

OWNERSHIP, INTERFACES AND STATUS

09 Module catalogue (1/3)

Owner area is the accountable engineering area; data ownership means the module is the only writer of those tables. Events are AuditEvent actions or job types (see p.32).

CURRENT VERIFIED

ID	MODULE · OWNER AREA	RESPONSIBILITIES	MAIN ENTITIES	PUBLIC INTERFACE	EVENTS EMITTED	DEPENDS ON	STATUS
M01	Identity & access Platform core	Authentication (JWT + Argon2), DB-authoritative session check, RBAC permission catalogue, enterprise SSO (OIDC / Entra), verification codes.	User, UserRole, SSOConfiguration, ExternalIdentityMapping, AuthVerificationCode	/auth, /sso, /users	user.*, role.* audit events	Organization & tenancy	✓ VERIFIED SSO code and tests present; production IdP configuration is external.
M02	Organization & tenancy Platform core	Tenant lifecycle (active, suspended, deletion-pending, restore), facilities, organisation settings, tenant-scoped base mixin.	Organization, Facility, TenantScopedMixin	/tenant, /facilities	organization.* audit events	Identity & access	✓ VERIFIED Organisation has a single org_type (ADR-007 multi-role table deferred).
M03	Suite, plan & subscription Commercial	Product catalogue (suite → module → page/feature), suite-bound plans, subscriptions, tenant overrides, usage limits, single entitlement resolver, billing abstraction, dunning.	ProductSuite, ProductModule, ProductFeature, Plan, PlanFeature, Subscription, TenantEntitlementOverride, Invoice, Payment	/entitlements, /product-catalog, /commercial-platform, /billing	subscription.*, plan.* audit; billing.dunningjob	Organization & tenancy	✓ VERIFIED Real payment provider external; legacy default plan mixes drone + aircraft features (documented gap).
M04	Asset registry & configuration Shared domain	Generic asset registry for all four families, aircraft/drone/helicopter/eVTOL detail tables, components, engines, batteries, installation history, asset resolution for ingestion.	Asset, Aircraft, AirframeDetails, Component, InstallationHistory, Battery, ExternalAssetMapping	/assets, /aircraft, /drones, /airframes, /fleet/components	component.installed/removed, battery.installed/removed	Tenancy, Entitlements	✓ VERIFIED Configuration-as-of view (ADR-010) partially realised via evaluation configuration_snapshot.
M05	Fleet operations Shared domain	Missions, flights, AOG events and recovery, control center, readiness inputs.	Mission, Flight, AogEvent	/missions, /aog, /control-center	mission.created/updated/authorized	Asset registry	✓ VERIFIED
M06	Telemetry acquisition & ingestion Data acquisition	Data sources, connectors (MAVLink v1/v2, MQTT, CSV/JSON, DJI, generic webhook, OEM pull), listeners, quality gate, asset/tenant mapping, quarantine, persistence, source health.	DataSource, TelemetryEventLog, HUMSSensorReading, EdgeDevice, BackgroundJob	/data-sources/{id}/ingest, /telemetry/*, /webhooks/data-sources/{id}, /edge-hardware/*	acquisition.ingest / acquisition.poll jobs; telemetry audit	Asset registry, Entitlements (flight_telemetry)	✓ VERIFIED Field validation (radios, brokers, OEM, DJI) external. Edge buffer is in-memory.

OWNERSHIP, INTERFACES AND STATUS

09 Module catalogue (2/3)

Owner area is the accountable engineering area; data ownership means the module is the only writer of those tables. Events are AuditEvent actions or job types (see p.32).

CURRENT VERIFIED

ID	MODULE · OWNER AREA	RESPONSIBILITIES	MAIN ENTITIES	PUBLIC INTERFACE	EVENTS EMITTED	DEPENDS ON	STATUS
M07	HUMS Intelligence	Feature extraction, baselines, drift, exceedances, diagnostics (fault signatures), degradation, prognostics/RUL estimate, per-sensor limits, finding + evidence creation.	HUMSSensor, HUMSFeature, HUMSBaseline, HUMSExceedance, HUMSDiagnosticCandidate, HUMSPrognosticRecord	/hums/*	Finding + Evidence rows; HUMS_* signals via M7 sync	Telemetry, Asset registry, Inspections (findings), Evidence	✓ VERIFIED Deterministic. Rotor / eVTOL-specific analytics need OEM data (external).
M08	Proactive intelligence (M7) Intelligence	Canonical owner of actionable signals: maintenance/inspection thresholds, recurring findings, utilisation, compliance-evidence gaps, readiness degradation, HUMS + telemetry-freshness signals; lifecycle (ack, review, resolve, dismiss).	ProactiveSignalRecord	/intelligence/signals, /intelligence/proactive	signal lifecycle audit; kota_m7_signals_total	HUMS, MRO, Compliance, Telemetry	✓ VERIFIED Signals are synced on read (GET triggers writes). Legacy /proactive alerts service still exposed.
M09	Cross-asset analytics (M14-ext) & fleet summary (M4.2) Intelligence	Descriptive fleet distributions (health, coverage, freshness, exceedance, diagnostic, prognostic); M4.2 per-asset decision summary; digital twin (derived, PostgreSQL).	(read-only views) FleetIntelligenceSummary	/intelligence/fleet, /aerospace-intelligence, /digital-twin	—	M7, HUMS, Asset registry	✓ VERIFIED Descriptive only; predictive cross-asset models are proposed.
M10	MRO Operations	Work orders + tasks, maintenance programme, deferred items, parts, inventory, procurement, purchase orders, receiving, vendors, technicians, TAT, release readiness, MRO intelligence.	WorkOrder, Task, MaintenanceRequirement, DeferredItem, Part, InventoryTransaction, PurchaseOrder, Vendor, TechnicianQualification	/work-orders, /maintenance, /parts, /procurement, /purchase-orders, /receiving, /release-readiness, /tat	work_order.*, task.* audit events	Asset registry, Inspections, Evidence	✓ VERIFIED
M11	Inspections & findings Operations	Inspection requirements (incl. RII), findings, dispositions, finding correlation.	InspectionRequirement, Finding	/inspections, /findings	inspection.*, finding.* audit events	Asset registry, Work orders	✓ VERIFIED
M12	Compliance & rules engine Compliance	Regulatory documents/requirements, deterministic applicability (Kleene three-valued logic), obligations, compliance assessments, assessment engine.	RegulatoryDocument, RegulatoryRequirement, ApplicabilityRule, ApplicabilityCondition, ApplicabilityEvaluation, ComplianceObligation, ComplianceAssessment, Assessment	/regulatory, /applicability, /compliance, /assessments	obligation sync audit	Asset registry, Evidence	⦿ PARTIAL Rules have no version column; ADR-005 human-decision lineage fields not in schema.

OWNERSHIP, INTERFACES AND STATUS

09 Module catalogue (3/3)

Owner area is the accountable engineering area; data ownership means the module is the only writer of those tables. Events are AuditEvent actions or job types (see [p.32](#)).

CURRENT

VERIFIED

ID	MODULE · OWNER AREA	RESPONSIBILITIES	MAIN ENTITIES	PUBLIC INTERFACE	EVENTS EMITTED	DEPENDS ON	STATUS
M13	Evidence management Compliance	Evidence records and lifecycle (required → accepted/rejected), files in S3-compatible storage with SHA-256 checksums, reconciliation, provenance.	Evidence, EvidenceFile	/evidence	evidence lifecycle audit	Object storage	✓ VERIFIED WORM / object-lock not configured in code (bucket policy is deployment-side).
M14	LISA & AI orchestration Intelligence	Intent and entity resolution, conversation context, tool registry (61 tools), per-call permission → subscription → suite → feature checks, deterministic airworthiness safety guard, provider abstraction.	LisaConversationContext, ToolSpec	/lisa	tools_invoked in response (not persisted)	All read services, Entitlements	🔔 PARTIAL Tool calls not written to the audit log; answer quality with a real provider is external.
M15	Notifications Platform core	Email for verification codes; tenant notification preferences.	(settings on tenant)	/tenant (preferences)	—	Email provider	🔔 PARTIAL No signal / work-order notification fan-out yet.
M16	Audit, export & reporting Governance	Immutable audit events (DB trigger), tenant export, hypercare; audit log doubles as the domain-event log.	AuditEvent	/platform/audit, exports	—	—	✓ VERIFIED Report pages (/reports) are labelled not-connected (product decision).
M17	Platform administration Governance	Platform control plane: provisioning, customer health, approvals (four-eyes), platform metrics, retention policies.	ApprovalRequest, RetentionPolicy	/platform/*	platform audit	All	✓ VERIFIED
X01	Jobs, scheduler & workers Runtime	Durable PostgreSQL job queue (SKIP LOCKED), retries, dead-letter, stale reclaim, idempotency keys, scheduler for retention, dunning, OEM polls.	BackgroundJob	python -m app.worker [--schedule]	kota_jobs_total	PostgreSQL	✓ VERIFIED

WHO MAY CALL WHOM

10 Domain ownership & dependency boundaries

Rows depend on columns. ‘read’ = calls a read service; ‘write’ = invokes the owner's write service (never its tables); × = prohibited; ‘gap’ = required check missing today.

HYBRID

	M01 IDENTITY	M02 ORGANIZATION	M03 SUITE, PLAN	M04 ASSET REGISTRY	M05 FLEET OPERATIONS	M06 TELEMETRY ACQUIS	M07 HUMS	M08 PROACTIVE INTELL	M09 CROSS-ASSET ANAL	M10 MRO	M11 INSPECTIONS	M12 COMPLIANCE	M13 EVIDENCE MANAGEM	M14 LISA	M16 AUDIT, EXPORT
M01 Identity		read													
M02 Organization	read														
M03 Suite, plan		read													
M04 Asset registry		read	read												
M05 Fleet operations			read	read											
M06 Telemetry acquisition		read	gap	read			write								
M07 HUMS				read		read				write			write		
M08 Proactive intelligence				read		read	read		read	read	read				
M09 Cross-asset analytics				read			read	read							
M10 MRO			read	read							read		write		
M11 Inspections				read					read						
M12 Compliance			read	read										read	
M13 Evidence management				read											
M14 LISA			read	read	read	read	read	read	read	read	×	read			
M16 Audit, export															

Data ownership rules

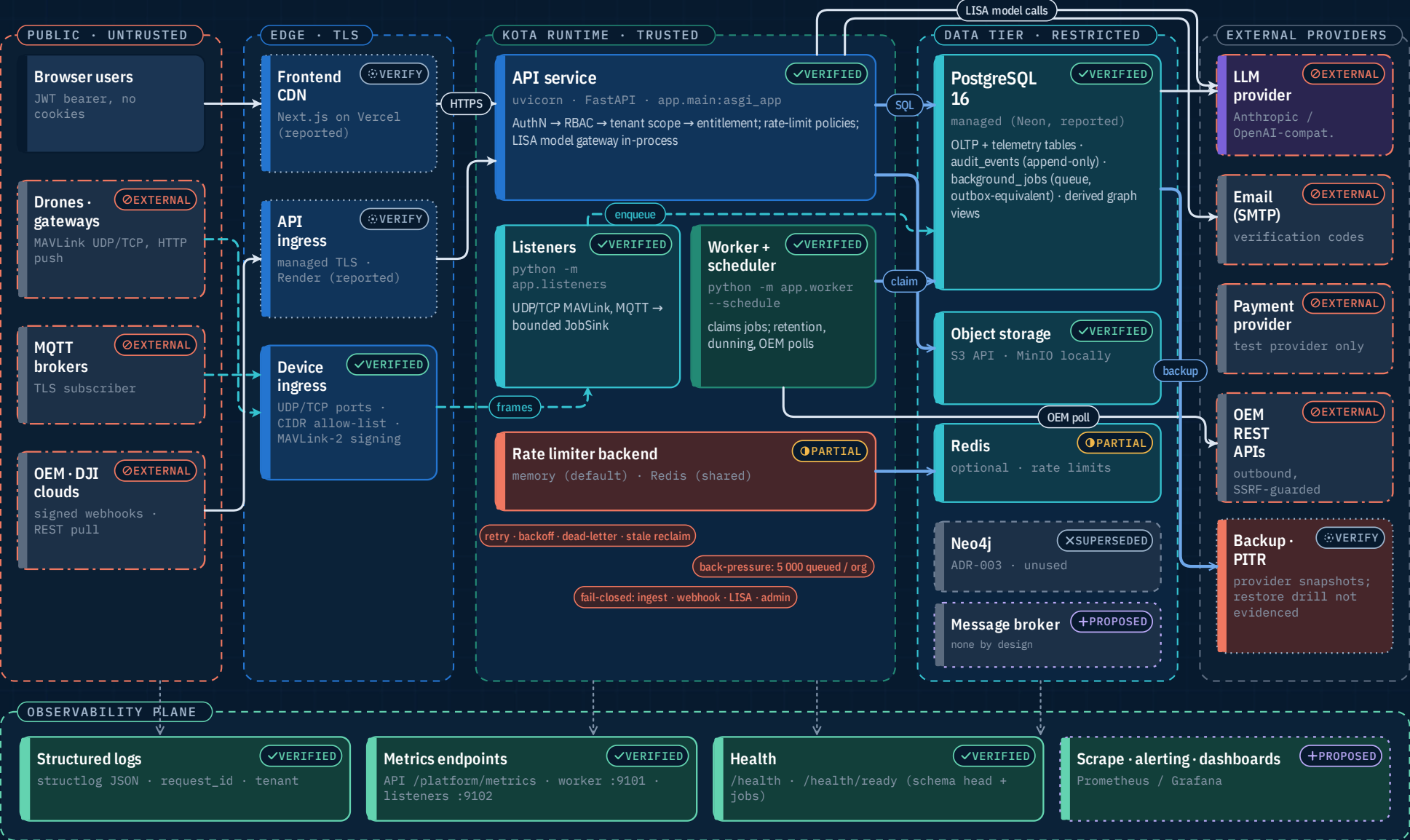
- One writer per table: the owning module's service.
- Cross-module writes go through the owner's service function inside the same transaction (e.g. HUMS → finding_service).
- Derived modules (M09, LISA) own no facts.
- Tenant id always from the caller or DataSource row.

Boundary findings

- M06 → M03: entitlement not re-checked on async paths (gap, F3).
- M14 → M12: LISA may trigger a deterministic assessment (run_assessment) but must never write compliance results (×).
- No import-linter contracts; enforce with CI (F5).

D04 INFRASTRUCTURE TOPOLOGY

HYBRID · RUNTIME VERIFIED IN CODE · HOSTING REPORTED



HOW TO READ Zones are trust boundaries; dashed coral pills are failure and retry boundaries. Neo4j is drawn because docker-compose starts it — it is SUPERSEDED, not used. Hosting providers come from reports and are marked VERIFY. → [current vs target p.17](#) · [security p.28](#)

COMPARISON SPREAD

12 Current vs target infrastructure

The target adds operations, not new architecture. Every row stays inside the modular-monolith, PostgreSQL-first decision.

HYBRID

COMPONENT	CURRENT (CODE + REPORTS)	TARGET (RECOMMENDED)	STATUS NOW
Web frontend	Next.js 16 on Vercel (reported)	Same; CDN caching for static assets	⚙️ VERIFY
API service	uvicorn, one image, \$PORT; migrations as separate step	≥2 instances behind TLS ingress; Gunicorn/uvicorn workers sized by test	🔴 PARTIAL
Worker & scheduler	python -m app.worker --schedule; PostgreSQL queue	Separate service; one scheduler leader; per-type concurrency	✅ VERIFIED
Listeners	python -m app.listeners (UDP/TCP/MQTT)	Dedicated host / static IP per region; sequence state per source	✅ VERIFIED
PostgreSQL	Managed (Neon, reported); plain tables	PITR verified by drill; partition telemetry by month when volume requires	🔴 PARTIAL
Cache / shared state	Redis optional, for shared rate limits	Required once API > 1 instance	🔴 PARTIAL
Object storage	S3 API; MinIO locally	Versioning + object lock (compliance mode) for evidence	🔴 PARTIAL
Message broker	None — by design	Only if fan-out / latency needs exceed the job queue (ADR-012)	+ PROPOSED
Graph store	Neo4j container unused	Remove; PostgreSQL derived views (ADR-011)	✖ SUPERSEDED
Telemetry store	hums_sensor_readings in PostgreSQL + retention	Native partitioning first; TimescaleDB only on measured need	+ PROPOSED
Model gateway	In-process provider abstraction (Anthropic / OpenAI-compatible)	Per-tenant routing incl. no-external-AI mode for sovereign tenants	+ PROPOSED
Observability	Prometheus-format endpoints, JSON logs, readiness	Scrape + alert rules + dashboards + log shipping	🔴 PARTIAL
Backup & DR	Provider snapshots (reported); runbook	Quarterly restore drill with measured RPO/RTO	⚙️ VERIFY

Why one database

Compliance answers years later need one transactional history. A second store of record would create the dual-write problem ADR-002 rules out.

When to add a store

Measured need only: telemetry partitioning first; a time-series engine if partitioned queries miss targets; a graph engine if traversal depth makes SQL the bottleneck.

Known data gaps

No partitioning on readings yet; MAVLink arrival-time stamping; signal ↔ work order link only in metadata; rule versions not stored.

STORES, OWNERSHIP AND THE CANONICAL TELEMETRY CONTRACT

13 Data architecture & data contracts

Kota keeps one database of record. Everything else is either a file referenced from it, a view derived from it, or process memory that may be lost.

CURRENT VERIFIED

Stores

STORE	HOLDS	OWNER	INTEGRITY
PostgreSQL 16	All transactional data, telemetry readings, audit log, job queue	Owning module per table	Tenant FK on every row; append-only audit (trigger)
Object storage	Evidence files, exports, retention archives	M13 Evidence	SHA-256 checksum; sanitised keys; presigned 300 s
Derived views	Digital twin, knowledge graph, fleet distributions	M09 (no ownership)	Rebuilt per read; never a source of truth
Process memory	Rate-limit counters (default), MAVLink sequence state, edge buffer	Runtime	Lost on restart — documented trade-off

Retention

DATA	RULE
Telemetry readings	policy-driven, dry-run default, archive-before-delete
Evidence & audit	kept (retention floor)
Jobs	succeeded jobs swept
Destructive mode	RETENTION_DESTRUCTIVE_ENABLED off by default

Canonical contract — NormalizedTelemetryEvent

FIELD	RULE (ENFORCED)
source_system / source_event_id	idempotency key with organisation (unique)
source_asset_id	resolved via explicit mapping → id → unique serial/registration
event_type · event_timestamp	UTC; naive, >5 min future, pre-2000 rejected
flight	one Flight per streaming session, advisory-locked per asset
battery	updates an existing battery only; never invents cycles
readings[]	sensor_code, measurement_type, value (finite), unit, component_id, data_quality
raw_metadata	timestamp_source = SOURCE RECEIVED

Processing states

RECEIVED → VALIDATED → PROCESSED, or DUPLICATE · REJECTED · QUARANTINED · FAILED. Reading quality: VALID, SUSPECT, MISSING, OUT_OF_RANGE, STALE, DUPLICATE, INVALID.

X02 · OBSERVATION → FINDING → DECISION → EVIDENCE → ACTION

PARTIAL — END-TO-END ID PROPOSED

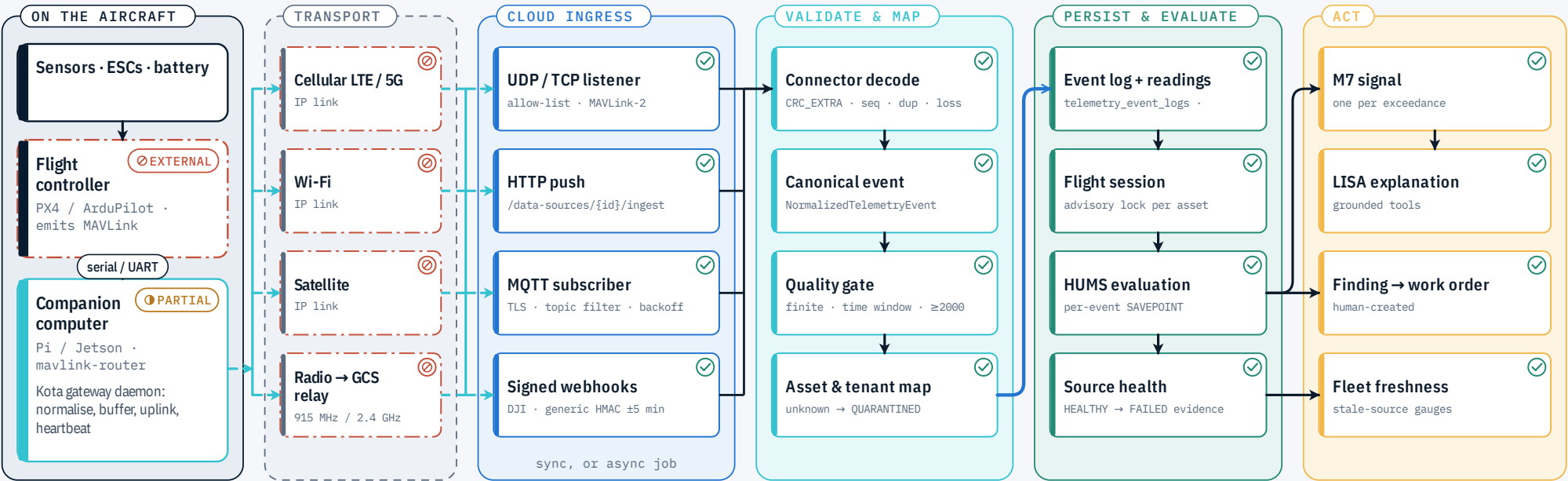


Verified links: packet → event log → reading → exceedance (contributing reading ids) → finding → evidence (provenance). Signal ↔ work order is a human action; the link is held in metadata, not a foreign key. Proposed (roadmap 4): one correlation id carried from packet to closed work order, and an outcome field on the work order that feeds HUMS baselines.

14 Drone-to-cloud connectivity

Every path ends in the same validated, tenant-safe pipeline. What is not yet proven is the physical path from an airborne autopilot to that pipeline without a laptop.

HYBRID



ALTERNATIVE ACQUISITION PATHS

A

Connected-aircraft service

DJI FlightHub 2 · OEM cloud → signed webhook or credentialed REST poll

✓ VERIFIED

software verified; real FlightHub / OEM tenancy external

B

Ground station · edge relay

GCS or mavlink-router forwards UDP/TCP to the listener; no laptop in the loop

EXTERNAL

needs a physical relay and network path

C

Store-and-forward

gateway queue drains after reconnect; arrival-time stamping today

PARTIAL

in-memory deque — proposed: disk queue + measured time

D

Automatic post-flight sync

flight log (ULog / DataFlash) → batch connector after landing

+ PROPOSED

CSV / JSON batch exists; native log parsers not built

E

Manual import — fallback only

operator uploads CSV / JSON through data import

✓ VERIFIED

validation · quarantine · dedup

DECISION GUIDE FOR AUTOMATED ACQUISITION

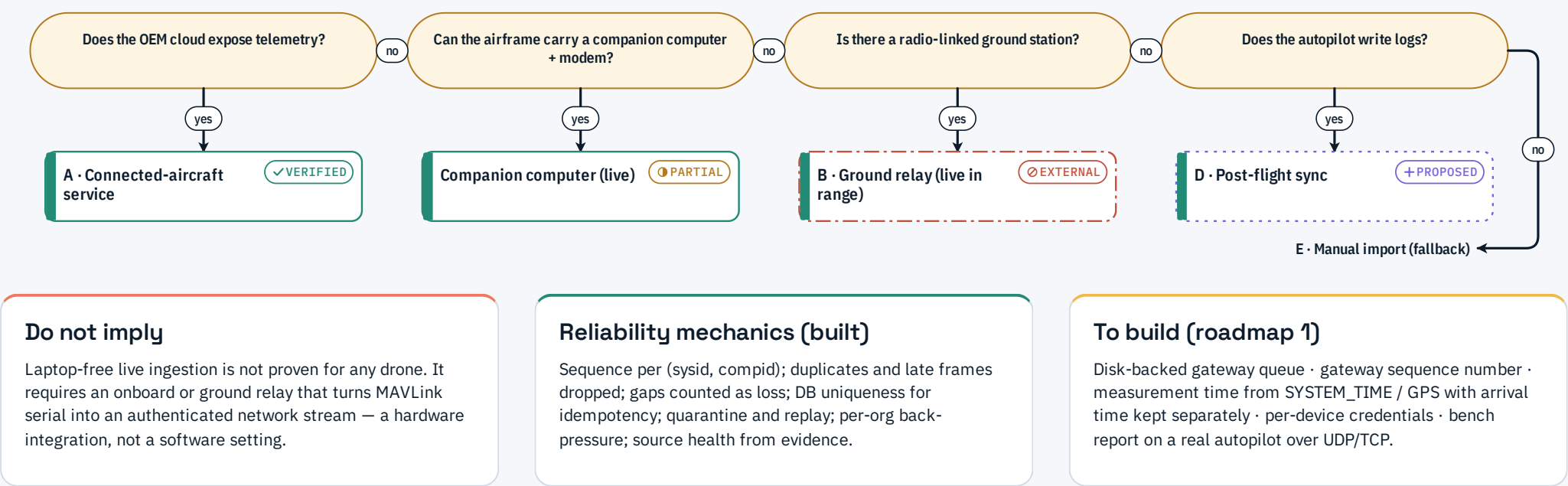
15 Connectivity options & dependencies

Choose per aircraft type. The software side is ready for all five; each row lists what must exist outside Kota.

HYBRID

PATH	FITS	NEEDS (HARDWARE / INTEGRATION / EXTERNAL)	TRADE-OFF	STATUS
Connected-aircraft service (OEM cloud)	DJI Enterprise / OEM fleets with cloud telemetry	Customer's OEM cloud tenancy + webhook secret or API credential	Lowest effort; OEM data model limits signals	✓ VERIFIED ⊘ EXTERNAL
Companion computer on aircraft	PX4 / ArduPilot airframes Kota or the customer can modify	Pi / Jetson, UART wiring, LTE modem, power, mounting, airworthiness of the modification	Best data, live; hardware integration required	🕒 PARTIAL ⊘ EXTERNAL
Ground station / edge relay	Radio-linked drones, no onboard modem	GCS or relay host running mavlink-router with internet uplink	Live within radio range; no airframe change	⊘ EXTERNAL
Automatic post-flight sync	Any autopilot that writes logs	Log parser (ULog / DataFlash) + sync agent on GCS or dock	Not live; complete data; simplest field ops	+ PROPOSED
Manual import	Fallback only	Operator uploads CSV / JSON	Human in the loop; not automation	✓ VERIFIED

Decision tree — first supported path per aircraft type

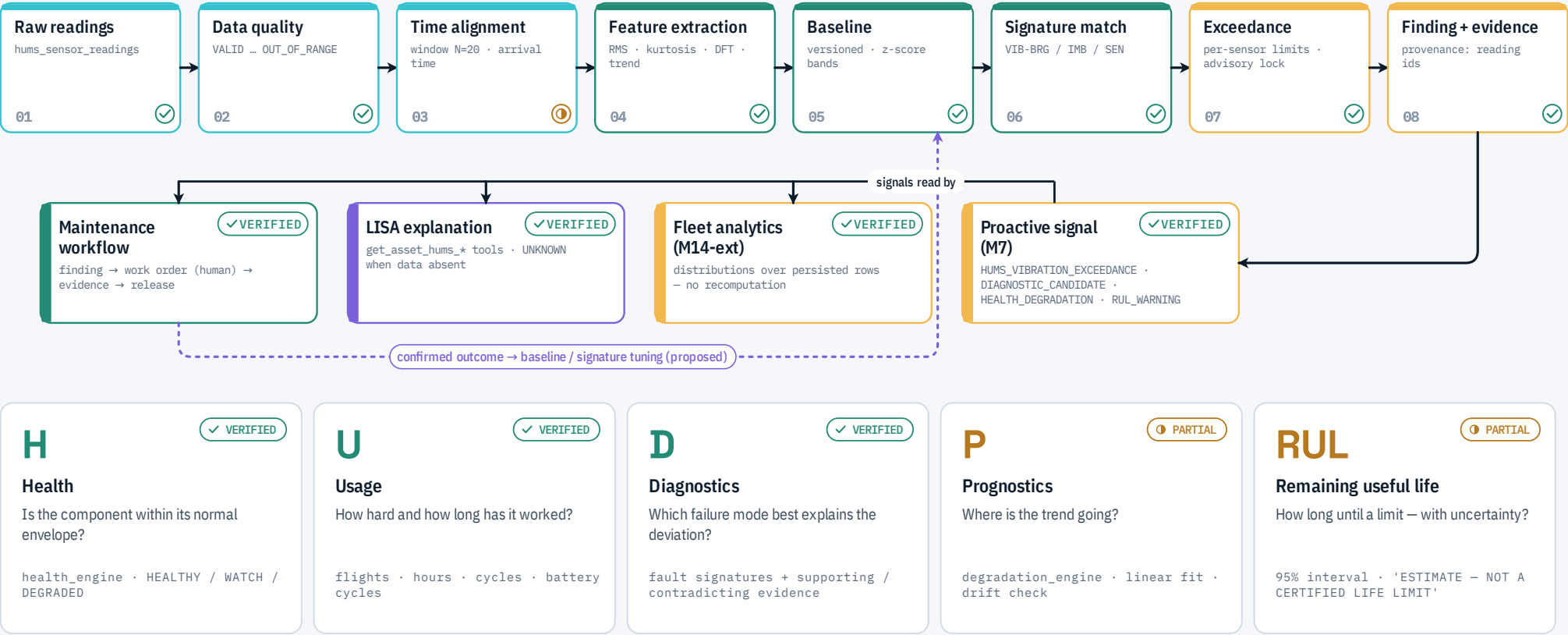


D06 · HEALTH, USAGE, DIAGNOSTICS, PROGNOSTICS, RUL

16 HUMS processing

A deterministic chain from reading to evidence-backed finding. Predictive models are deliberately absent until outcome data exists.

HYBRID



PROPOSED – PREDICTIVE MODELS (NOT BUILT)

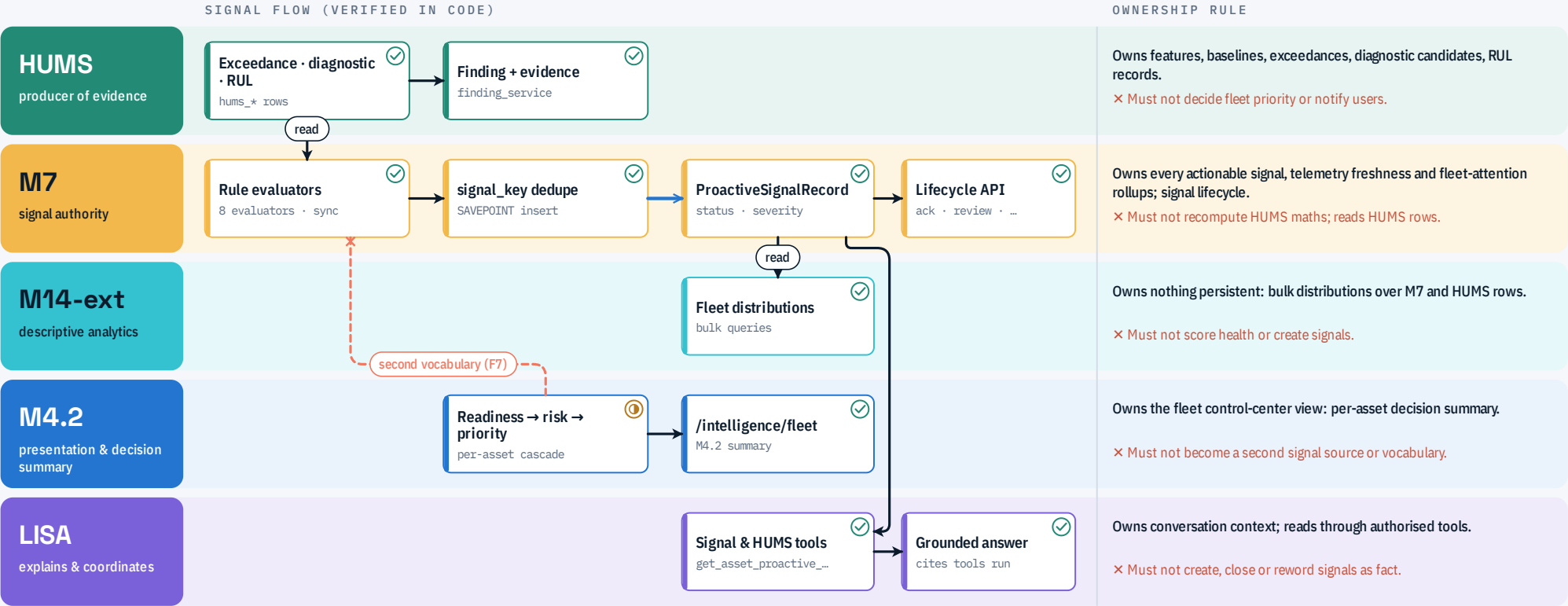
Learned prognostic models per component class, fleet-relative baselines and rotor / eVTOL condition indicators (track & balance, gearbox CI, propulsor efficiency). Prerequisites: outcome-labelled maintenance data (confirmed removals), OEM data and a validation protocol. Until then RUL stays a deterministic linear estimate tagged AVAILABLE / LIMITED / INSUFFICIENT_DATA / LOW_CONFIDENCE / STALE.

D07 · ONE SIGNAL AUTHORITY

17 M7, M14-ext and M4.2 ownership

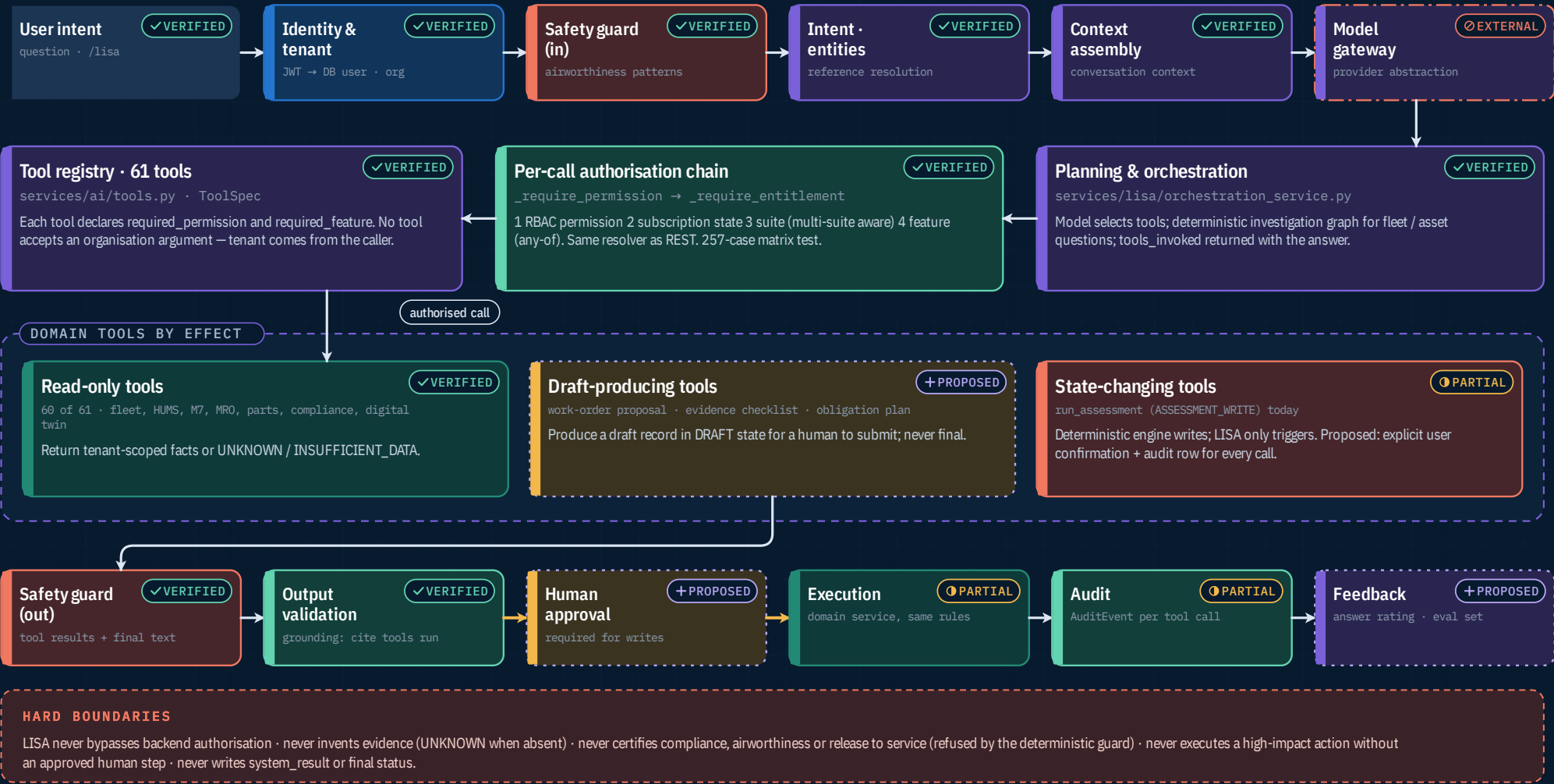
M7 owns actionable signals; M14-ext describes the fleet; M4.2 presents decisions; LISA explains. HUMS produces the evidence they all read.

CURRENT VERIFIED



D08 LISA & AGENTIC AI ARCHITECTURE

HYBRID · TOOLS VERIFIED · GOVERNED WRITES PROPOSED



HOW TO READ

Top row: request path. Middle: the authorisation chain shared with REST. Lower: tool classes and the governed-write tail. Proposed elements are what turns LISA from a grounded reader into a bounded agent. → [workFlows p.24](#) · [entitlements p.27](#)

BOUNDED AGENTS, NOT AUTONOMOUS ONES

19 Agentic workflows

An agentic workflow here is a planned sequence of authorised tool calls that ends either in an answer or in a draft for a human. None ends in a regulated state change.

HYBRID

WORKFLOW	TOOLS / DATA	CLASS	HUMAN GATE	STATUS
Telemetry triage	get_asset_telemetry_status · get_asset_proactive_signals · get_asset_hums_*	Read	None (explanation only)	✓ VERIFIED
Maintenance planning	signals + work orders + parts availability → draft work order with tasks and parts	Draft	Planner submits the draft; RII and release remain human	+ PROPOSED
Compliance evidence discovery	obligations + evidence + requirements → missing-evidence list, draft checklist	Read → draft	Reviewer accepts evidence; LISA never marks compliant	⦿ PARTIAL
Fleet analysis	fleet distributions, M7 summary, digital twin	Read	None	✓ VERIFIED
Workflow coordination	propose next steps across WO / procurement / inspections	Draft	Each state change confirmed by an authorised user	+ PROPOSED

Model routing & grounding

One provider per deployment today (Anthropic or OpenAI-compatible; “not configured” otherwise). Proposed: per-tenant routing including a no-external-model mode for sovereign customers; answers must cite tool results; absence returns UNKNOWN.

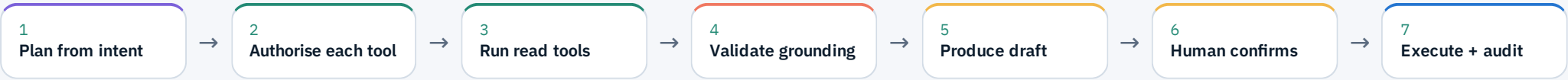
Safety-critical boundary

Deterministic guard runs on the question, on tool results and on the final text: airworthiness, release-to-service, CRS, skip / bypass inspection phrasings are refused outside the model.

Before adding agents

Persist every tool call as an AuditEvent; classify tools; add a confirmation step for writes; build an evaluation set from real operator questions (roadmap 7). Do not add agents while F3 and F5 are open.

Bounded agent loop (target)

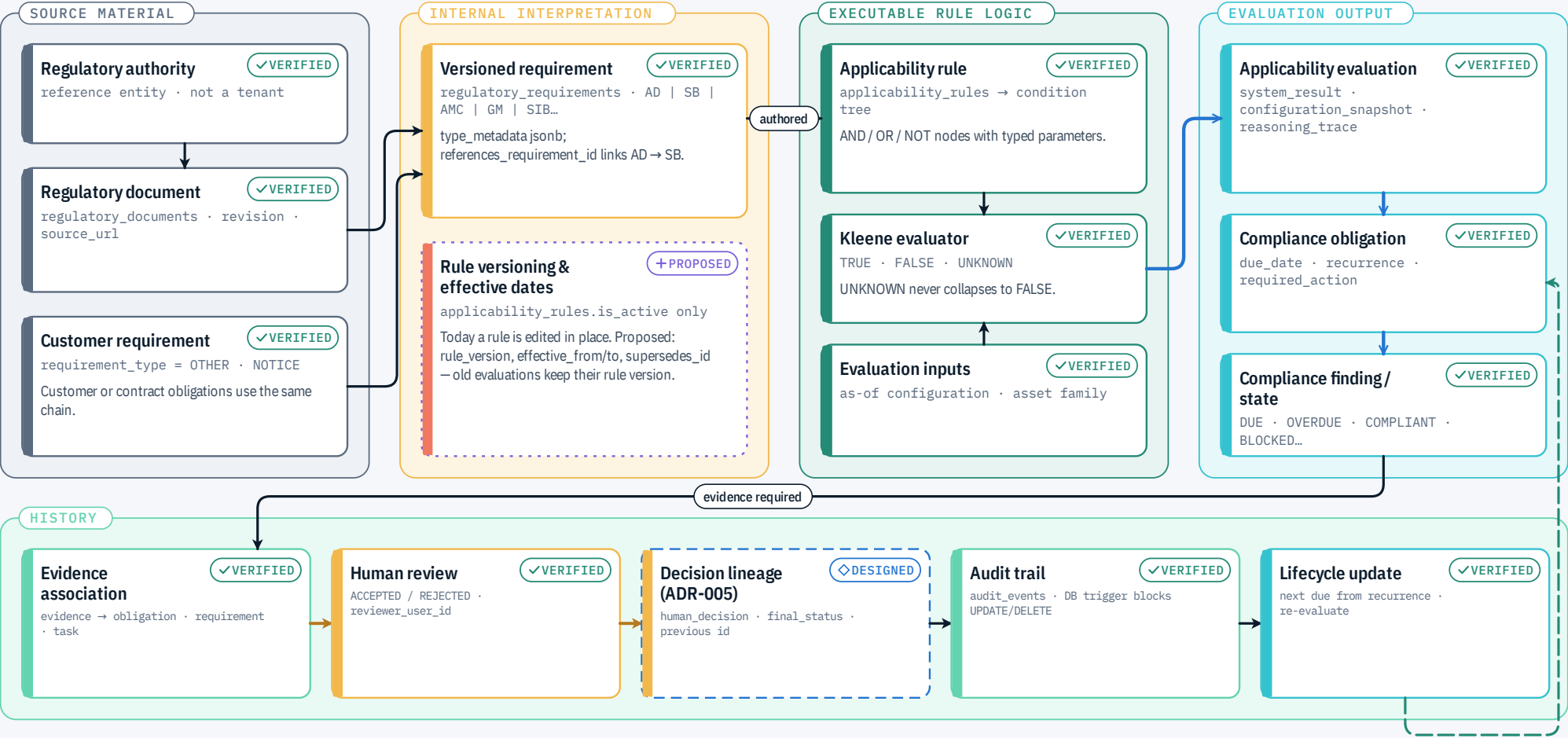


D09 · SOURCE → INTERPRETATION → EXECUTABLE LOGIC → OUTPUT

20 Compliance & rules engine

Source material, the engineer's interpretation, the executable rule and its evaluation are separate records, so each can be reviewed and revised without rewriting history.

HYBRID

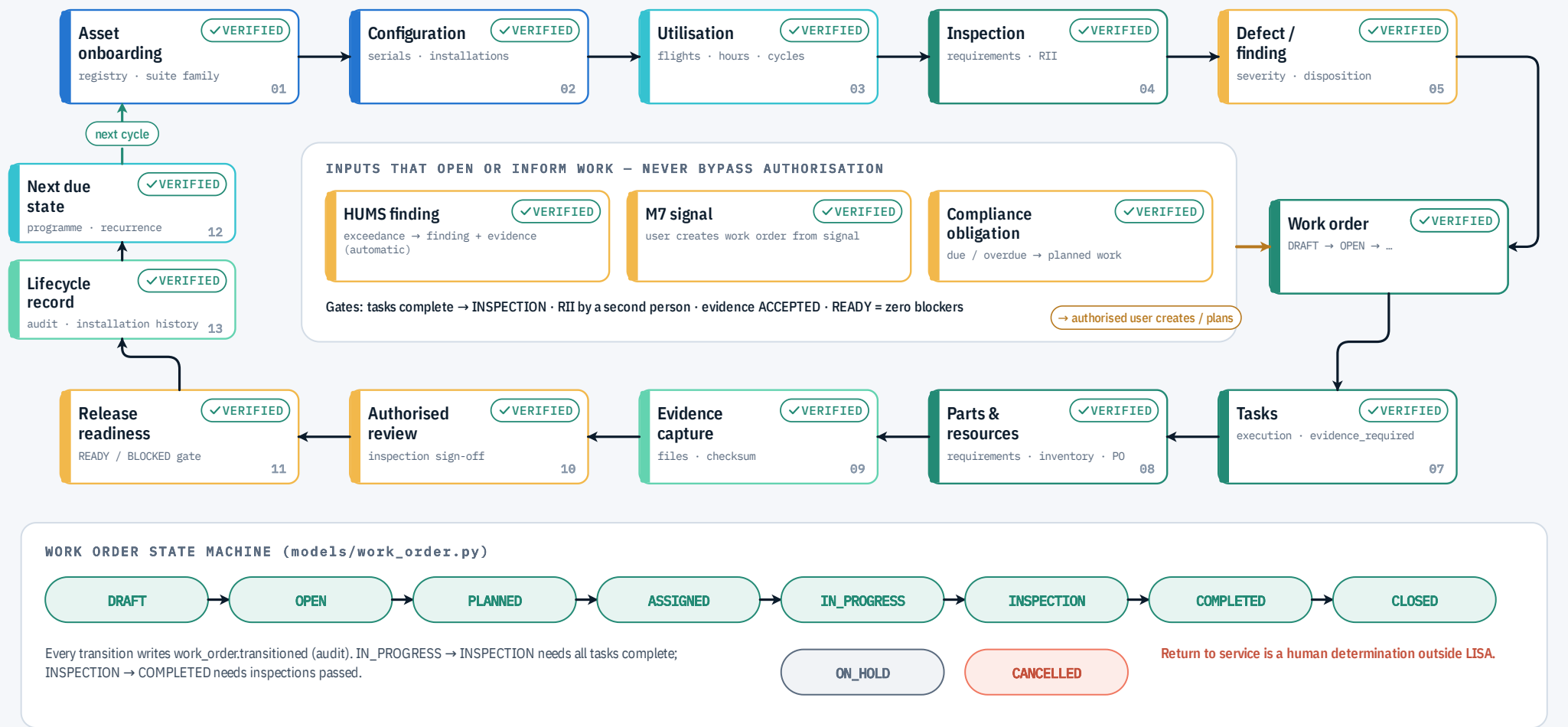


D10 · FROM ONBOARDING TO THE NEXT DUE STATE

21 MRO & asset lifecycle

HUMS findings, M7 signals and compliance obligations all inform maintenance, but only an authorised user creates or advances work.

CURRENT VERIFIED

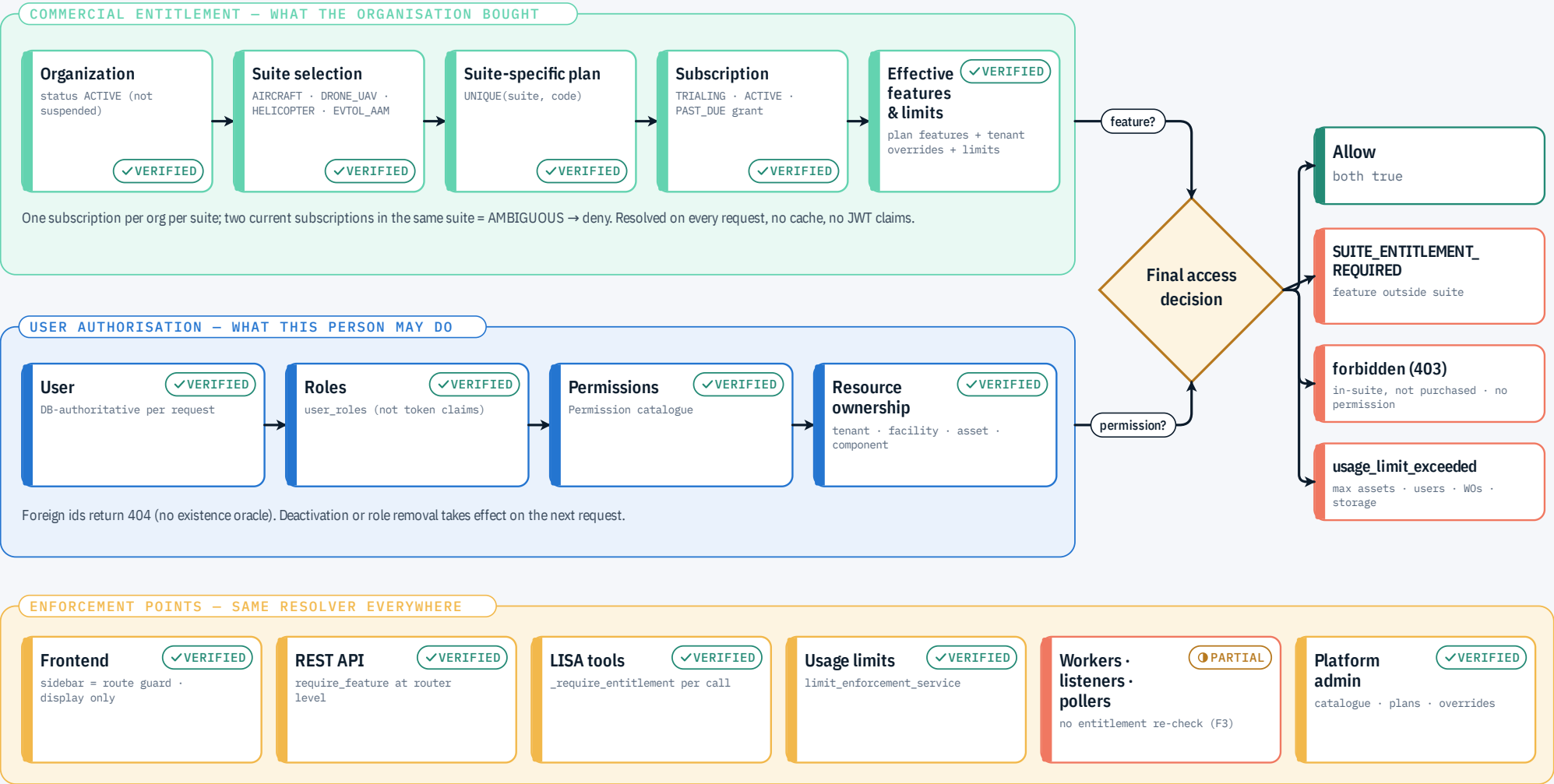


D11 · COMMERCIAL ENTITLEMENT VS USER AUTHORISATION

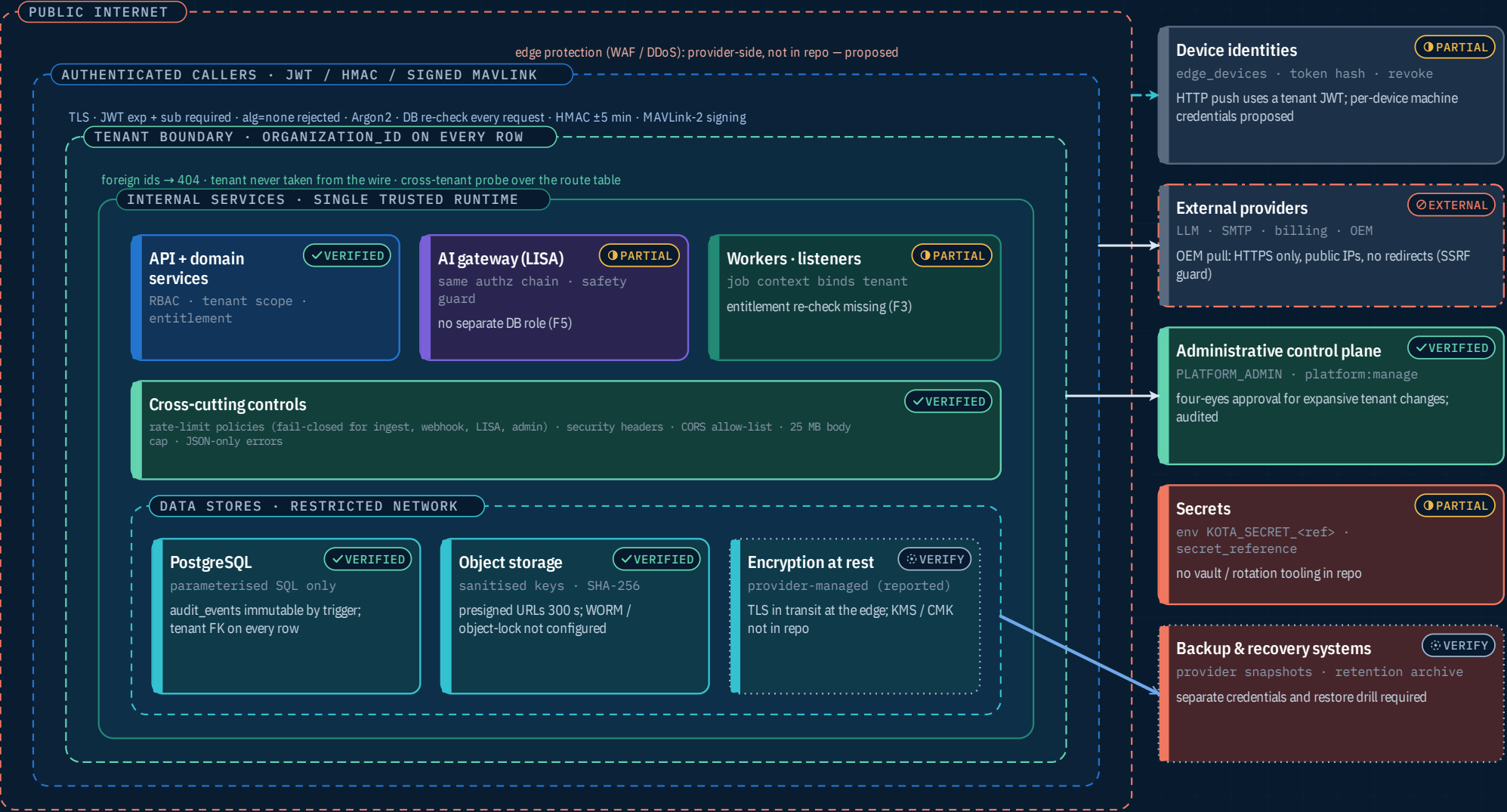
22 Multi-tenancy, plans & entitlements

Two independent questions — did the organisation buy it, and may this person do it — answered server-side on every request and combined into one decision.

CURRENT VERIFIED



D12 SECURITY & TRUST BOUNDARIES



CONTROL REGISTER

24 Security controls & sovereignty

No certification or defence-grade compliance is claimed. Controls below are those found in code; the right-hand column is the work needed before such a claim could be evaluated.

HYBRID

CONTROL	IMPLEMENTED	STATUS	NEXT STEP
Authentication	JWT (exp + sub required), Argon2, DB re-check per request, SSO (OIDC/Entra)	✓ VERIFIED	MFA policy at IdP; token revocation list
Authorisation	RBAC permissions + router-level entitlements + ownership checks	ⓘ PARTIAL	Async paths (F3)
Tenant isolation	organization_id on every row; 404 for foreign ids; cross-tenant probe tests	✓ VERIFIED	Optional PostgreSQL RLS as defence in depth
Encryption	TLS at edge (reported); at rest provider-managed (reported)	⚙️ VERIFY	Document CMK / KMS per environment
Secret management	env KOTA_SECRET_; credentials refused in config JSON	ⓘ PARTIAL	Vault / cloud secret manager + rotation
Audit	Immutable audit_events (trigger); lifecycle transitions audited	✓ VERIFIED	LISA tool calls (F5)
Data residency	No region model in code	+ PROPOSED	Region per tenant; sovereign deployment profile
Device credentials	Edge device token hash, revoke; MAVLink-2 signing keys	ⓘ PARTIAL	Per-device push credentials; rotation
AI tool security	Per-call authz, no org argument, safety guard, rate limit	✓ VERIFIED	Tool classes; confirmation for writes
Retention & evidence integrity	Archive-before-delete; evidence checksums	ⓘ PARTIAL	Object lock; periodic checksum verification

Sovereign deployment profile (ADR-016, proposed)

Same images, single-tenant stack in the customer's chosen region or private cloud; own database, storage and keys; model gateway set to an approved or on-premise provider or disabled; no shared observability backend.

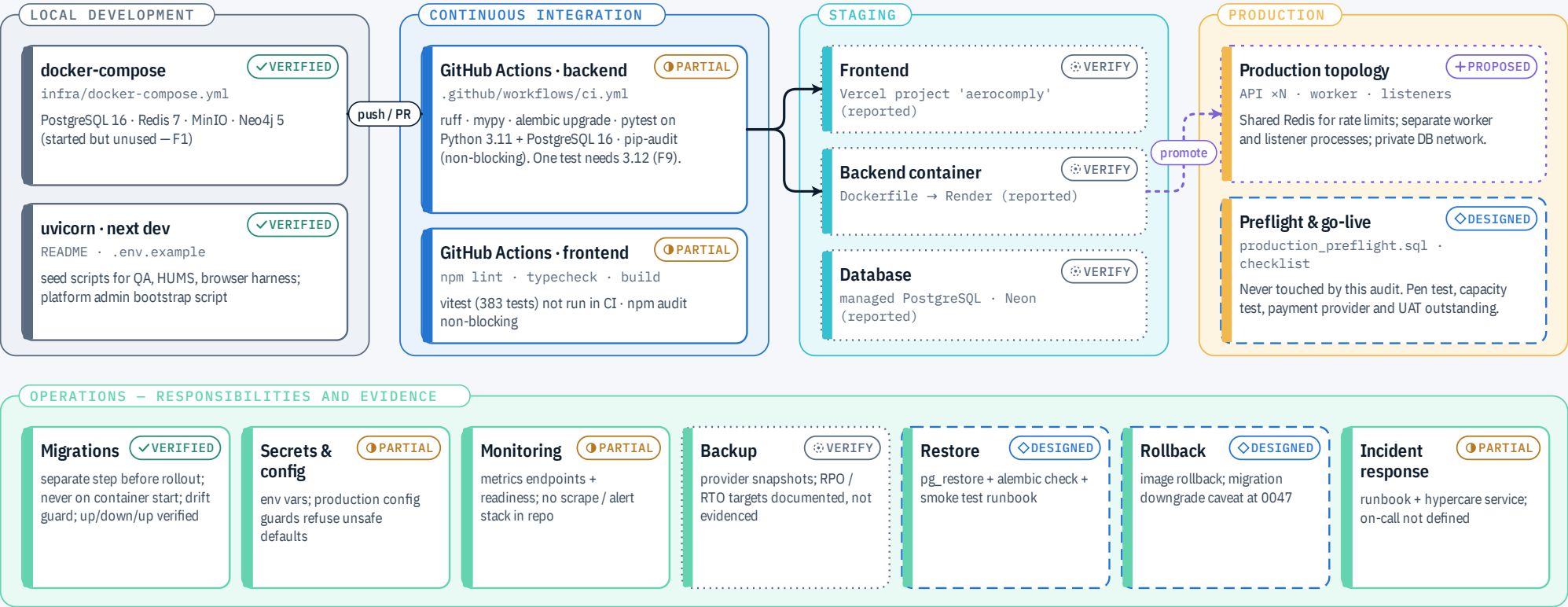
Open verification

- External penetration test
- Dependency audit as a blocking CI gate
- Infrastructure hardening review
- DNS-rebinding residual risk on OEM polling — run workers with egress filtering

25 Deployment topology

Local and CI are verified from the repository. Staging and production hosting appear only in reports and were not inspected; the production topology is a recommendation.

HYBRID



Release order

1 preflight SQL on a restore · 2 alembic upgrade head · 3 roll API, worker, listeners · 4 readiness reports schema head · 5 smoke tests.

Rollback

Roll the image back first; downgrade migrations only when safe — 0047 refuses to downgrade over existing non-task evidence rows by design.

Not done

Capacity test on production-like hardware, restore drill, on-call rota, alerting. This audit did not touch any hosted environment.

FAILURE MODES AND SIGNALS

26 Reliability & observability

Most failure handling is already in code; what is missing is the operational loop that watches it.

HYBRID

FAILURE	BEHAVIOUR TODAY	MITIGATION	STATUS
Database unavailable	readiness 503; API errors; jobs wait	Managed HA; alert on readiness	✓ VERIFIED
Schema mismatch after deploy	readiness 503 schema_mismatch	Release order; drift guard test	✓ VERIFIED
Worker crash mid-job	job stays RUNNING → reclaimed after 10 min	Visibility timeout; idempotent handlers	✓ VERIFIED
Poison message	retries with backoff → DEAD	Dead-letter inspection + requeue	✓ VERIFIED
Ingestion flood	per-org queue cap 5 000 → drop + count	Back-pressure metric alert	✓ VERIFIED
Rate-limit backend down	fail-closed for sensitive policies, local fallback otherwise	Shared Redis HA	✓ VERIFIED
Link loss in flight	gateway buffers in memory; oldest dropped on overflow	Disk queue (F4)	⚠ PARTIAL
Listener restart	MAVLink sequence state forgotten	One listener per source or persisted state	⚠ PARTIAL
LLM provider outage	LISA reports not configured / error; domain unaffected	Fallback provider	✓ VERIFIED
Region loss	—	Backup restore in second region; drill	⚙ VERIFY

Service objectives (proposed)

OBJECTIVE	TARGET
API availability	99.5 % monthly (proposed)
Ingest-to-signal latency	p95 < 60 s for async path (proposed)
Telemetry freshness	stale source alert at 3× expected interval (built gauge)
Dead jobs	alert on any DEAD job (proposed)
Restore	RPO 15 min / RTO 1 h — targets until a drill measures them

Signals already emitted

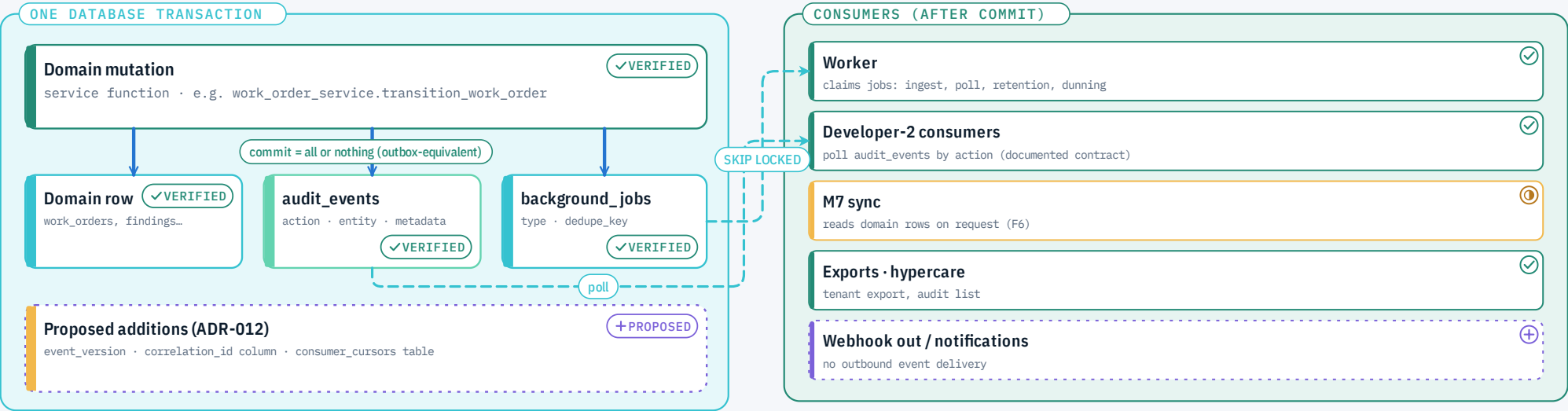
HTTP, auth and authorisation failures, rate limiting, ingest, packet loss, job outcomes, queue depth by status, data-source health, M7 signal events, HUMS evaluations, LISA tool latency and errors; JSON logs with request, tenant and correlation ids.

EVENTS WITHOUT A BROKER

27 Integration & event architecture

State change, its audit event and any follow-up job commit in one transaction. That gives outbox guarantees for jobs today; ADR-012 formalises versioning and consumer cursors.

HYBRID



EVENT CATALOGUE IN USE (action strings verified in code)			
Missions	mission.created · updated · authorized		
Work orders	work_order.created · updated · assigned · transitioned		
Configuration	component / battery .installed · .removed		
Signals	M7 lifecycle transitions (audited)		
Findings	finding.created · disposition_added · closed		
Tasks	task.created · updated · completed		
Inspections	inspection.completed · rejected · reopened		
Jobs	acquisition.ingest · .poll · retention.sweep · billing.dunning		

Queue semantics

At-least-once, effectively-once via idempotent handlers; unique (job_type, dedupe_key); exponential backoff with jitter; dead-letter; stale reclaim; correlation id carried into logs.

Versioning & replay

No event_version today; consumers read action strings. Replay = re-query audit_events by time window. Proposed: version field, consumer cursor table, replay command.

External integration

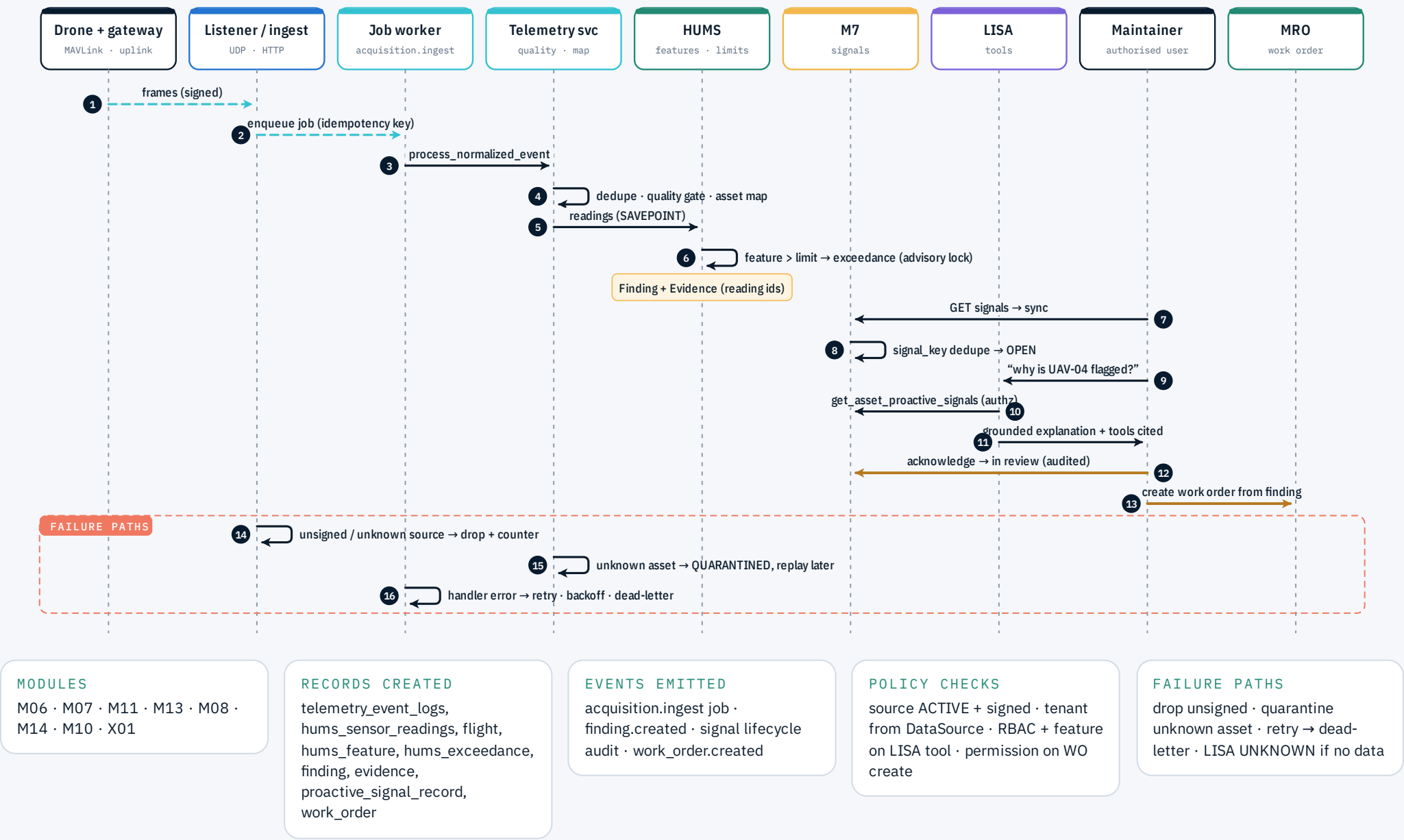
Inbound: webhooks (HMAC), OEM pull, MQTT, MAVLink. Outbound: email only. Outbound webhooks or notifications should be driven from the same jobs table.

D14.1 · END-TO-END SCENARIO

28 Drone anomaly → reviewed maintenance

A flight produces a vibration exceedance; HUMS evaluates it, M7 raises a signal, LISA explains it, and a person decides the maintenance action.

CURRENT VERIFIED

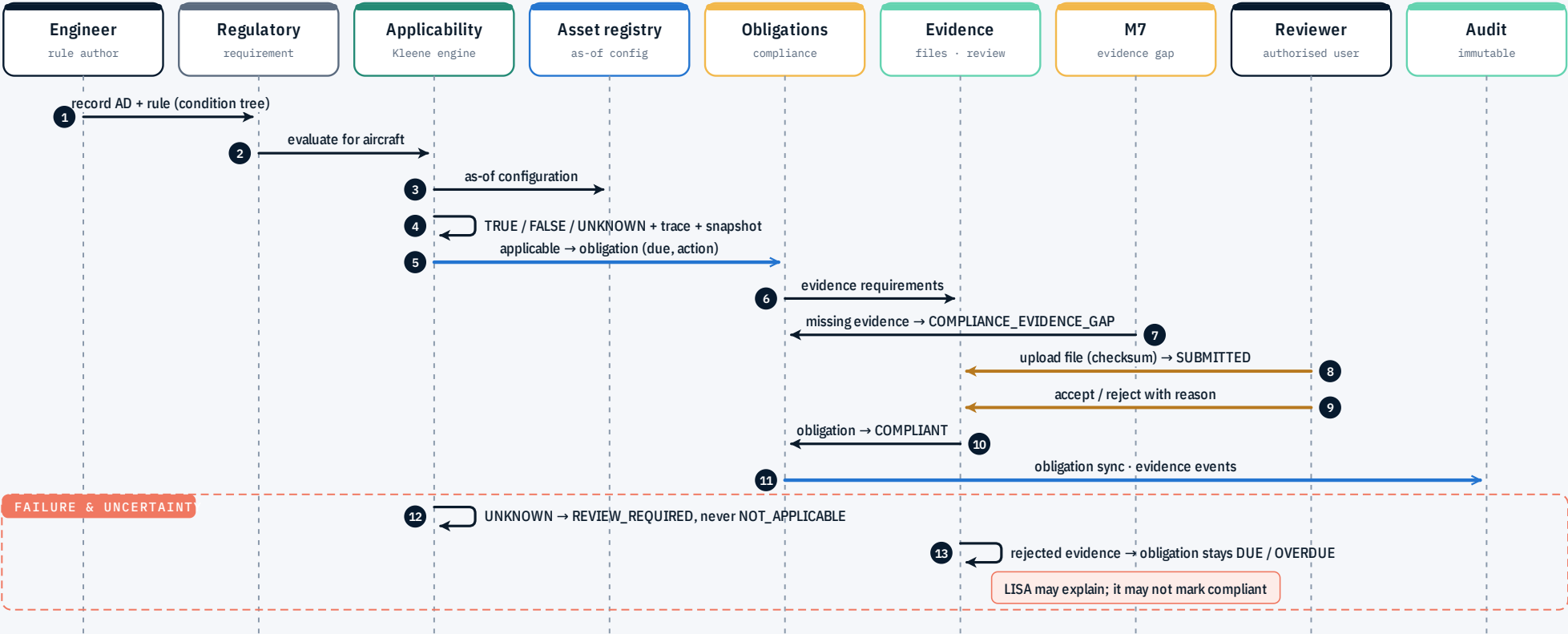


D14.2 · END-TO-END SCENARIO

29 Compliance obligation → evidence → review

A requirement applies to an aircraft; the rules engine decides applicability, finds missing evidence, and an authorised reviewer closes it.

CURRENT VERIFIED



MODULES

M12 · M04 · M13 · M08 · M16

RECORDS CREATED

regulatory_requirement, applicability_rule + conditions, applicability_evaluation (snapshot, trace), compliance_obligation, evidence, evidence_file

EVENTS EMITTED

obligation sync audit · evidence lifecycle audit · COMPLIANCE_EVIDENCE_GAP signal

POLICY CHECKS

compliance_management feature · REGULATION / ASSESSMENT permissions · reviewer ≠ uploader (recommended)

FAILURE PATHS

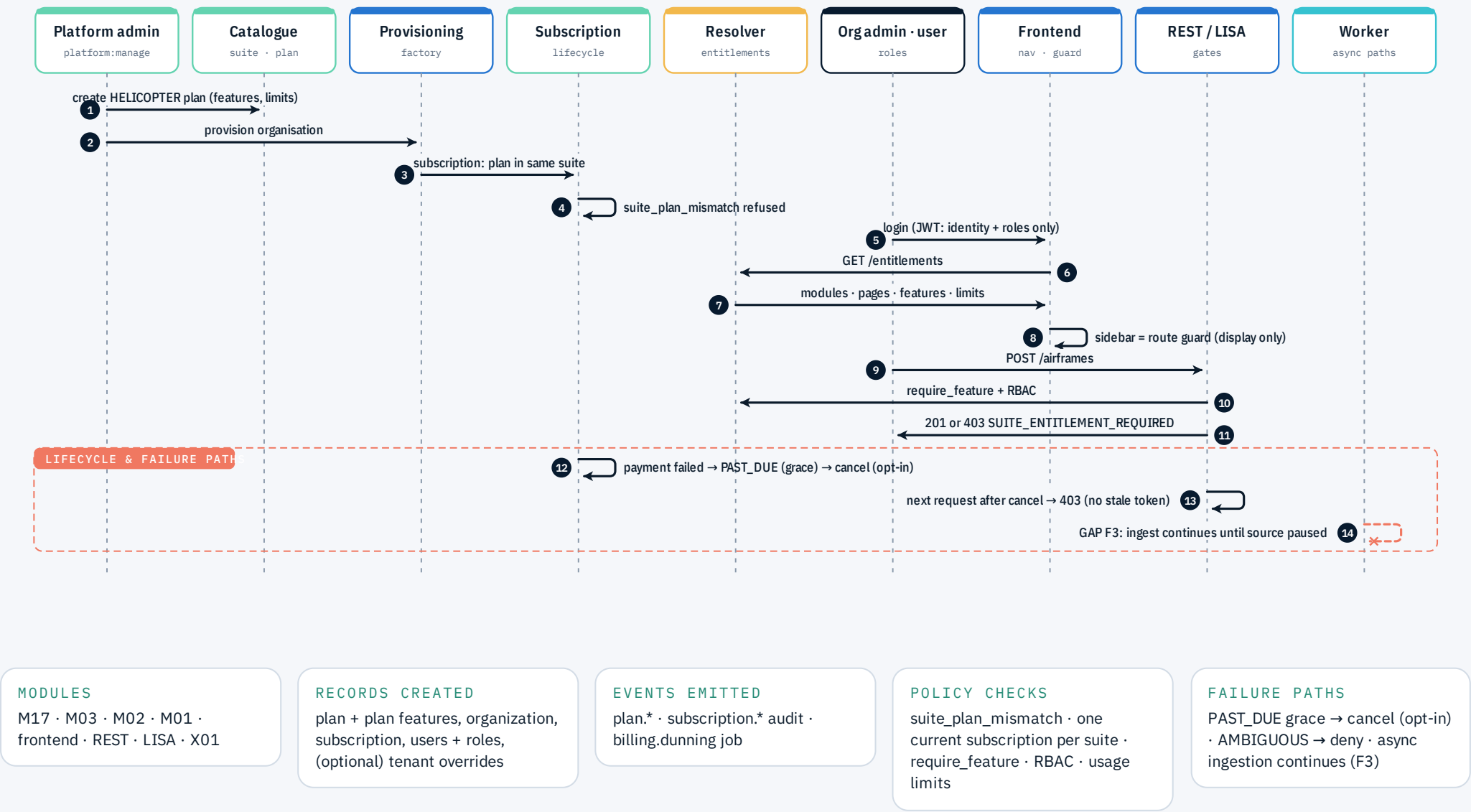
UNKNOWN → review required · rejected evidence keeps obligation open · rule edit not versioned (F8)

D14.3 · END-TO-END SCENARIO

30 Subscription → features → permissions

An organisation subscribes to a suite plan; the resolver turns that into features and limits, combined with the user's permissions on every path.

VERIFIED + GAP F3



44 CAPABILITIES, ONE VOCABULARY

31 Implementation status register

Status as of commit 6bd38ce. ‘Software complete, gap count 0’ in the repository's own matrix is consistent with this register for software that can be tested locally; it does not cover the EXTERNAL, VERIFY or PROPOSED rows.

CURRENT VERIFIED

21	6	2	6	5	3	1
✓ VERIFIED	🕒 PARTIAL	🔹 DESIGNED	+ PROPOSED	🚫 EXTERNAL	🔍 VERIFY	✕ SUPERSEDED
Identity, RBAC, SSO	✓ VERIFIED	Learned prognostics	+ PROPOSED	WORM evidence storage	🔍 VERIFY	
Tenancy & isolation (HTTP)	✓ VERIFIED	M7 signals + lifecycle	🕒 PARTIAL	Immutable audit log	✓ VERIFIED	
Suite / plan / subscription	✓ VERIFIED	M14-ext distributions	✓ VERIFIED	Job queue + scheduler	✓ VERIFIED	
Billing (test provider)	🕒 PARTIAL	M4.2 fleet summary	✓ VERIFIED	Rate limiting (shared Redis)	🕒 PARTIAL	
Real payment provider	🚫 EXTERNAL	Digital twin (SQL)	✓ VERIFIED	Metrics, logs, readiness	✓ VERIFIED	
Asset registry, 4 families	✓ VERIFIED	Neo4j projection	✕ SUPERSEDED	Alerting / dashboards	+ PROPOSED	
Missions, flights, AOG	✓ VERIFIED	LISA tools + authz	✓ VERIFIED	Retention	✓ VERIFIED	
MAVLink codec + signing	✓ VERIFIED	LISA tool audit persistence	🔹 DESIGNED	Async entitlement re-check	🕒 PARTIAL	
UDP/TCP/MQTT listeners	✓ VERIFIED	LISA governed writes	+ PROPOSED	Notifications fan-out	+ PROPOSED	
Signed webhooks, OEM polling	✓ VERIFIED	Work orders, tasks, RII, release gate	✓ VERIFIED	Staging hosting	🔍 VERIFY	
Serial MAVLink listener	🚫 EXTERNAL	Parts, procurement, inventory	✓ VERIFIED	Backup / restore drill	🔍 VERIFY	
Durable edge buffer	🕒 PARTIAL	Applicability engine	✓ VERIFIED	Penetration test	🚫 EXTERNAL	
Physical RF / autopilot validation	🚫 EXTERNAL	Rule versioning	+ PROPOSED	Customer UAT	🚫 EXTERNAL	
Post-flight log parsers	+ PROPOSED	ADR-005 decision lineage	🔹 DESIGNED	10 sample-only pages	🕒 PARTIAL	
HUMS deterministic chain	✓ VERIFIED	Evidence + checksums	✓ VERIFIED			

TEN FINDINGS FROM THE AUDIT

32 Architecture gaps & corrections

Ordered by severity. Each finding names the evidence; none required changing application code during this audit.

CURRENT VERIFIED

ID	SEVERITY	FINDING AND EVIDENCE	CORRECTION
F1	HIGH	Neo4j decision conflict ADR-003 (Accepted) and the M14 report describe Neo4j as a derived graph fed by an outbox. The code uses PostgreSQL only (knowledge_graph.py, digital_twin_service.py); neo4j_* settings are unused, yet docker-compose still starts Neo4j. The gap matrix records the change but ADR-003 was never superseded.	Write ADR-011 superseding ADR-003; remove Neo4j from local compose or mark optional.
F2	HIGH	No transactional outbox / event bus Domain events are AuditEvent rows consumed by polling; asynchronous work uses the background_jobs table enqueued inside the request transaction. This is outbox-equivalent for jobs, but there is no versioned event contract, no consumer offsets and no replay tool.	Formalise audit + jobs as the event backbone (event_version, correlation_id), not a broker.
F3	HIGH	Async ingestion ignores entitlement changes Router-level require_feature guards the HTTP surfaces, but job handlers, listeners and OEM polls do not re-resolve entitlements. A tenant whose subscription is cancelled keeps ingesting through an ACTIVE data source until it is paused.	Check flight_telemetry entitlement in acquisition_service.ingest and the poll scheduler.
F4	HIGH	Store-and-forward is not durable The edge gateway buffers in a bounded in-memory deque (oldest dropped on overflow, lost on power cycle), and MAVLink events are stamped with arrival time, so post-flight synchronised data loses its true measurement time.	Disk-backed queue on the gateway; carry SYSTEM_TIME / GPS epoch and a gateway sequence number.
F7	HIGH	Signal vocabulary drift (with a live defect) /proactive (legacy computed alerts + daily brief) coexists with M7 /intelligence/signals. 'M14' names both the commercialisation milestone and the cross-asset intelligence service; signal_type is a free string(64). Concrete defect: M7's overdue-maintenance rule filters work orders on AWAITING_PARTS / SCHEDULED, which are not WorkOrderStatus values, so PLANNED, ASSIGNED, ON_HOLD and INSPECTION work orders never raise overdue signals (proactive_intelligence_service.py:74).	Fix the status filter to WorkOrderStatus constants; retire or fold /proactive into M7; registry for signal types.
F5	MEDIUM	AI write boundary is convention, not structure ADR-004/005 require a separate DB role for the AI module without write grants. LISA runs in the API's own session; one tool (run_assessment) writes. ADR-001's import-linting is not configured. Tool invocations are returned to the caller but not persisted to the audit log.	Classify tools read / draft / write; persist every tool call as an AuditEvent; add import-linter contracts.
F6	MEDIUM	Reads that write (signal sync on GET) M7 sync_and_get_signals and HUMS get_asset_health_intelligence persist records during GET requests. Correct today (idempotent keys, advisory locks) but couples read latency to write contention and makes the signal authority depend on who reads first.	Move sync to worker jobs triggered by telemetry / MRO events; keep GET read-only.
F8	MEDIUM	Compliance lineage and rule versioning Applicability evaluations keep configuration_snapshot and reasoning_trace (good), but rules have no version and the ADR-005 human-decision / final-status / previous-assessment lineage is not in the schema.	Add rule_version + effective dating; implement ADR-005 decision rows or amend the ADR.
F9	MEDIUM	CI runtime drift CI and the Dockerfile pin Python 3.11, but tests/integration/test_observability.py uses 3.12-only f-string syntax and fails collection on 3.11. CI also does not run the frontend vitest suite. In this audit's independent run one listener test failed deterministically (a start-up race in the test).	Pin Python 3.12 everywhere (or fix the test); add vitest to CI.
F10	LOW	Documentation drift Several documents describe targets as if built (Redis cluster, TimescaleDB, ai_tool_audit_log, WORM storage, RPO < 15 min). Most now carry status banners; FINAL_RELEASE_READINESS still lists G1 as open while the gap matrix lists it closed.	Treat this blueprint's status register as the index; banner or archive superseded documents.

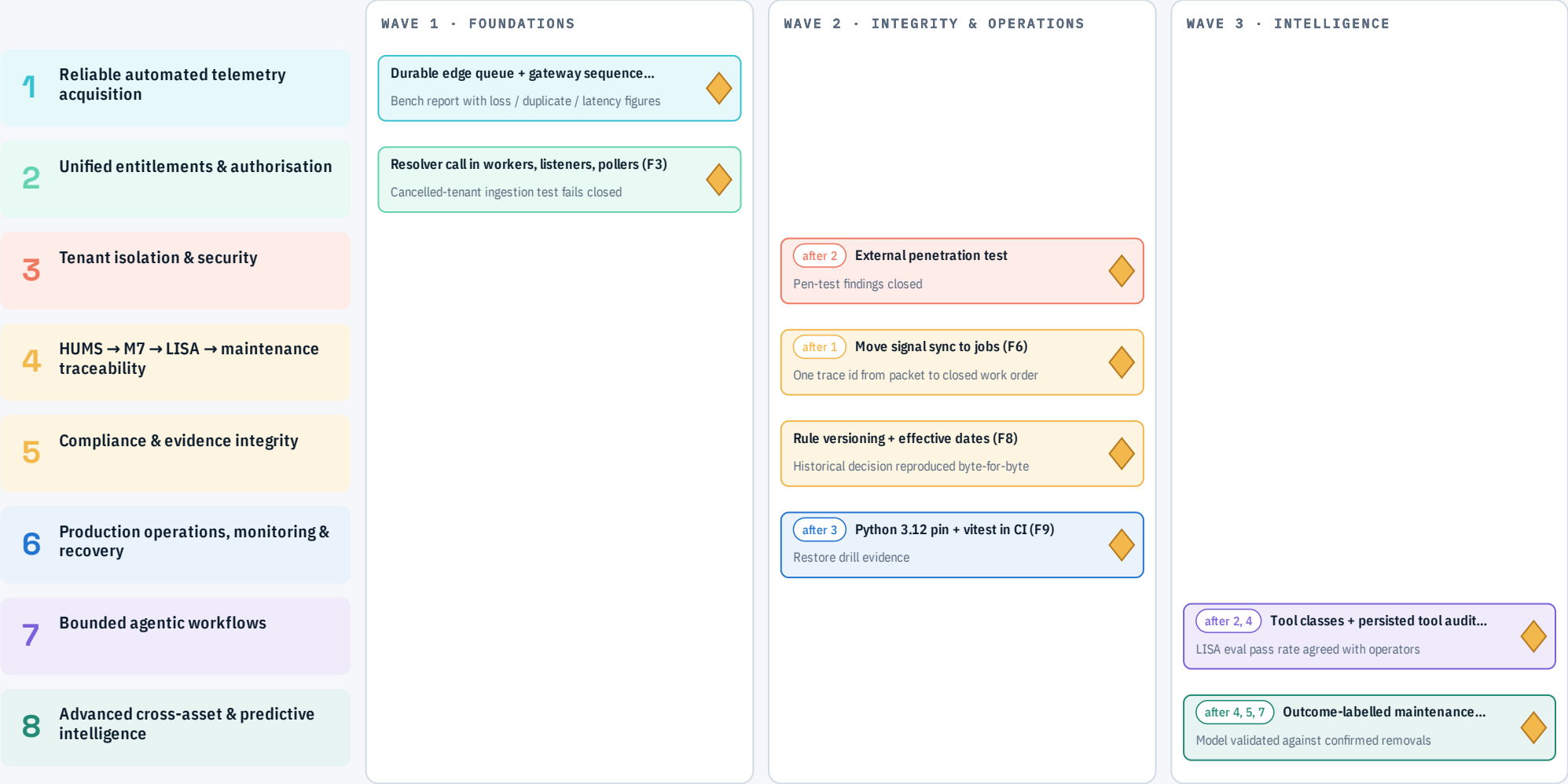
DEPENDENCY-AWARE, FOUNDATION FIRST

33 Recommended technical roadmap

Advanced AI and prediction come last because they amplify whatever is underneath: if acquisition, permissions or lineage are unreliable, so are the answers.

TARGET / PROPOSED

X03 · ROADMAP — ORDER BY DEPENDENCY, NOT BY DATE



DETAIL

33 Roadmap — work items and exit gates

Each workstream closes on evidence, not on a date. Items reference the findings they resolve.

TARGET / PROPOSED

#	WORKSTREAM	WORK ITEMS	AFTER	EXIT GATE (EVIDENCE)
1	Reliable automated telemetry acquisition	· Durable edge queue + gateway sequence numbers (F4) · Measurement-time contract for MAVLink (SYSTEM_TIME / GPS) · Per-device machine credentials for push · Physical bench: MAVLink over UDP/TCP via mavlink-router on a companion computer	—	Bench report with loss / duplicate / latency figures
2	Unified entitlements & authorisation	· Resolver call in workers, listeners, pollers (F3) · Fix legacy mixed-suite default plan · Suite boundary as data, not code	—	Cancelled-tenant ingestion test fails closed
3	Tenant isolation & security	· External penetration test · Shared Redis rate limiter in multi-instance · Secrets manager (replace env KOTA_SECRET_*)	2	Pen-test findings closed
4	HUMS → M7 → LISA → maintenance traceability	· Move signal sync to jobs (F6) · Signal-type registry; retire/proactive (F7) · Signal → work order link with outcome feedback	1	One trace id from packet to closed work order
5	Compliance & evidence integrity	· Rule versioning + effective dates (F8) · ADR-005 decision lineage · Object-lock / WORM bucket policy + checksum re-verify job	—	Historical decision reproduced byte-for-byte
6	Production operations, monitoring & recovery	· Python 3.12 pin + vitest in CI (F9) · Prometheus scrape + alert rules · Tested restore drill (measured RPO/RTO)	3	Restore drill evidence
7	Bounded agentic workflows	· Tool classes + persisted tool audit (F5) · Draft-only work-order proposals with human confirmation · Evaluation set of real operator questions	2, 4	LISA eval pass rate agreed with operators
8	Advanced cross-asset & predictive intelligence	· Outcome-labelled maintenance data · Fleet-relative baselines · Validated prognostic models per component class	4, 5, 7	Model validated against confirmed removals

TEN RECORDED DECISIONS, CHECKED AGAINST CODE

34 Architecture decision register

Decision status is the ADR's own; implementation is this audit's verdict. ADR-003 is the one decision the code has overturned.

CURRENT VERIFIED

ADR	DECISION · STATUS	PROBLEM	APPROACH	ALTERNATIVES	TRADE-OFFS	RISK OBSERVED	VALIDATION NEEDED	IN CODE
ADR-001	Modular monolith Accepted	Small team, unproven boundaries, AI must never share compliance write paths.	One FastAPI deployable; internal modules; boundaries by review + import linting.	Microservices; undifferentiated app.	Coarse scaling; discipline required.	Boundaries erode: import-linter not configured; module folders ai/, graph/, rules_engine/ are empty stubs while code lives in services/.	Add import-linter contracts in CI.	✓ VERIFIED
ADR-002	PostgreSQL as source of truth Accepted	Legally defensible traceability for years.	PostgreSQL 16 holds all transactional, tenant, audit data.	Neo4j primary; dual-primary.	Graph traversals more verbose in SQL.	Telemetry growth in plain tables (no partitioning).	Capacity test; partition hums_sensor_readings by month when needed.	✓ VERIFIED
ADR-003	Neo4j as derived knowledge graph Accepted (on paper)	Multi-hop reassessment candidates.	Neo4j projection via outbox, rebuildable.	Recursive CTEs in PostgreSQL.	Extra store and sync.	Code took the alternative; ADR never updated.	Record ADR-011 (PostgreSQL derived graph) and its reversal condition.	✗ SUPERSEDED
ADR-004	LLM is not the compliance decision engine Accepted	Airworthiness conclusions must be reproducible.	Rules engine decides; AI explains read-only.	LLM-as-verifier; LLM + mandatory sign-off.	Rule authoring is human work.	Separate AI DB role not implemented; enforcement is application-level + safety regex.	DB role or service-layer write guard for LISA; persisted tool audit.	⦿ PARTIAL
ADR-005	Human decision boundary Accepted	One mutable status conflates system, human and final positions.	Immutable lineage: system_result → human_decision → final_status.	Mutable status; side table.	More rows.	applicability_evaluations has system_result + snapshot but no human_decision / final_status / previous id.	Implement decision rows or amend the ADR to the evidence-review + approval model actually built.	⦿ PARTIAL
ADR-006	Regulatory requirement as core abstraction Accepted	AD, SB, AMC... share one shape.	RegulatoryRequirement + type discriminator.	Table per type; EAV.	Type filters in queries.	—	—	✓ VERIFIED
ADR-007	Shared organisation abstraction Proposed	Operator / CAMO / MRO / lessor roles.	One Organization table, single org_type; OrganizationRole later.	Table per role; boolean flags.	Multi-role orgs pick one role.	Onboarding of multi-role customers.	Confirm with first CAMO/MRO customer.	⦿ PARTIAL
ADR-008	Engine as first-class assessable asset Proposed	Engines carry their own AD stream.	Engine as assessment subject (subject_type).	Engine as component.	Polymorphic subject.	Evaluation uses aircraft_id/asset_id; engine subject not confirmed.	Confirm engine-subject evaluations in tests.	⚙️ VERIFY
ADR-009	Component / instance / installation split Proposed	Serialized vs lot parts; reinstall history.	Three concepts.	Four tables; single table.	Joins.	—	Map to components + installation_history as built.	⦿ PARTIAL
ADR-010	Configuration as derived as-of view Proposed	'What configuration did the aircraft have then?'	As-of query + immutable per-evaluation snapshot.	Mutable current-config blob.	Query cost.	—	Reproducibility test (re-derive snapshot).	⦿ PARTIAL

FOR THE PRODUCT AND ENGINEERING OWNERS

35 Decisions & trade-offs requiring approval

Six proposed decisions and five open questions. None is implemented; each lists the evidence that would reverse it.

TARGET / PROPOSED

ID	PROPOSED DECISION	WHY IT FITS	REVERSE IF	STATUS
ADR-011	PostgreSQL-native derived graph (supersedes ADR-003)	Matches the code; keeps one store; GraphRepository seam allows Neo4j later.	Traversal depth/fan-out makes SQL a measured bottleneck.	+ PROPOSED
ADR-012	Audit log + job table as the event backbone	Already transactional and immutable; add event_version, correlation_id, consumer cursor table.	Real-time fan-out to >3 independent consumers or cross-process push needed.	+ PROPOSED
ADR-013	Entitlement check on every execution path	REST, LISA, workers, listeners and schedulers call one resolver before acting.	—	+ PROPOSED
ADR-014	LISA tool classes and write governance	read / draft / state-changing classes; state-changing tools require explicit human confirmation and are audited.	—	+ PROPOSED
ADR-015	Edge time and durability contract	Gateway disk queue, gateway sequence number, measurement time from autopilot epoch; arrival time kept separately.	—	+ PROPOSED
ADR-016	Sovereign / dedicated deployment profile	Single-tenant stack per sensitive customer using the same images; no shared AI provider unless approved.	Only if no defence customer is pursued.	+ PROPOSED

Key trade-offs

Modular monolith vs microservices. Keep the monolith. Split candidates, in order, only on evidence: listeners (network exposure), worker (scaling), LISA (provider isolation).

PostgreSQL vs specialised stores. Partition telemetry before adopting TimescaleDB; object storage for files; no second database of record.

Telemetry storage & retention. Raw readings retained per policy; features and exceedances kept; evidence never deleted.

Multi-tenant isolation. Shared schema with tenant FK now; RLS as defence in depth; dedicated stacks for sovereign tenants.

Questions only you can answer

1. Does the brief's 'Neo4j as derived index' principle stand, or is ADR-011 (PostgreSQL) accepted?
2. Which connectivity path (D05 A–E) is the first supported production path, and on which airframe?
3. Build or retire the 10 sample-only pages (/finance, /reports, /workspace ...)?
4. Is a sovereign / defence deployment a 2027 requirement? It changes model routing and hosting.
5. Who owns this blueprint and approves ADR changes?

REFERENCE

36 Glossary, diagram legend & change history

Acronyms are expanded here once; the legend is on page 03.

TERM	MEANING
AD	Airworthiness Directive — mandatory regulatory requirement issued against a type certificate.
ADR	Architecture Decision Record — documented decision with context, alternatives and consequences.
AOG	Aircraft on Ground — asset unable to operate pending maintenance or parts.
Applicability	Deterministic evaluation of whether a requirement applies to an asset configuration (TRUE / FALSE / UNKNOWN).
Data source	Tenant-bound configuration of one telemetry feed (connector type, mapping, health).
Entitlement	Commercial right to a feature, resolved from suite → plan → subscription → overrides → limits.
eVTOL / AAM	Electric vertical take-off and landing / advanced air mobility.
Exceedance	A reading or feature beyond a configured warning / critical limit or statistical threshold.
HUMS	Health and Usage Monitoring System — health, usage, diagnostics, prognostics.
Kleene logic	Three-valued logic where UNKNOWN is never silently treated as FALSE.
LISA	Kota's grounded assistant — answers only from authorised tool results.
M4.2	Fleet intelligence control center — presentation and decision summary over per-asset intelligence.

TERM	MEANING
M7	Proactive intelligence — canonical owner of actionable signals and their lifecycle.
M14-ext	Cross-asset intelligence extension (H8.1) — descriptive fleet distributions. Not the M14 commercial milestone.
MAVLink	Lightweight message protocol for drones and autopilots; a framing format, not a cloud endpoint.
MRO	Maintenance, repair and overhaul.
Outbox	Pattern where events are written in the same transaction as state, then published asynchronously.
RBAC	Role-based access control (permissions per role, checked server-side).
RII	Required Inspection Item — independent inspection by a second qualified person.
RUL	Remaining Useful Life — estimate, never a certified life limit.
Signal	Persisted, actionable M7 record with severity, explanation trace and lifecycle.
SKIP LOCKED	PostgreSQL row-locking mode letting parallel workers claim different jobs.
Suite	Product family: Aircraft, Drone/UAV, Helicopter, eVTOL/AAM.
Tenant	A customer organisation; every row carries organization_id.

Change history

VERSION	DATE	CHANGE
v1.0	2026-10-01	First edition: audit of commit 6bd38ce, 14 diagram families, status register, 10 findings, roadmap, decision register.

Diagram index

D01 master ecosystem · D02 layers · D03 modules · D04 infrastructure · D05 connectivity · D06 HUMS · D07 intelligence ownership · D08 LISA · D09 compliance · D10 MRO · D11 entitlements · D12 security · D13 deployment · D14.1–3 scenarios · X01 events · X02 lineage · X03 roadmap.

Editable sources

src/diagrams.py (all diagrams, Python → SVG) · src/model.py (modules, findings, ADRs, roadmap) · svg/*.svg · mermaid/*.mmd · ARCHITECTURE_SOURCE_OF_TRUTH.md.